

Project Janatha Auth/Event Red-Team Report

Focused local assessment of authentication and event creation/management

Generated: 2026-07-06T23:30:35

Scope: local v2 working tree, local Wrangler D1, local API <http://127.0.0.1:8787/api>.

No production, preview, or third-party systems were attacked or modified. Tokens are redacted in screenshots.

Scores are CVSS-style severity ratings for internal triage; no official CVE IDs are assigned.

Metric	Count
Confirmed vulnerability groups	18
Confirmed failing controls	130
Controls with CVSS-style score ≥ 8.0	75
Attempted controls	132

Severity	Finding Groups	Control Failures
Critical	3	7
High	9	68
Medium	5	41
Low	1	14

Exact Reproduction

Start the local backend, then run the harness below. It creates local-only fixtures, records observed API responses, captures proof screenshots, and writes the JSON source of truth.

```
QA_PASSWORD='PreviewTest2026!' bun qa-artifacts/security-auth-events-2026-06-29/run-auth-event-redteam.mjs
```

Source evidence: [qa-artifacts/security-auth-events-2026-06-29/auth-event-findings.json](#). Screenshots are PNG files in the same directory.

Remediation Update

This section records the code fixes applied after the original auth/event red-team run. Original screenshots remain in the detailed finding pages as before-fix proof; the verification table below records the post-fix test results.

ID	Status	Fix Summary	Verification
AE-F001	Fixed	Admin authorization now uses <code>verification_level >= ADMIN_CUTOFF</code> instead of mutable email identity. Self-service email changes are blocked outside a verified email-change flow.	Covered by backend app auth/admin tests and backend typecheck.
AE-F002	Fixed	Invite-only registration requires a valid invite for normal, developer, and bootstrap addresses. Bootstrap/admin promotion is no longer available from email alone.	Covered by invite gate registration tests in <code>app.test.ts</code> .
AE-F003	Fixed	<code>authMiddleware</code> and auth routes now deny inactive and suspended accounts before returning authenticated data.	Covered by inactive/suspended auth regression tests in <code>app.test.ts</code> .
AE-F004	Fixed	Rate limiting no longer trusts spoofable X-Forwarded-For. It keys on Cloudflare's connecting IP when present, then host fallback in local tests.	Covered by backend app rate-limit regressions and full suite.
AE-F005	Fixed	Malformed JSON and unexpected route failures are handled by generic API errors instead of returning internal parser/stack details.	Covered by malformed body and error handling regressions in <code>app.test.ts</code> and <code>passwordReset.test.ts</code> .
AE-F006	Fixed	Profile mutation now blocks email changes, rejects self-service center reassignment across auth and legacy profile routes, validates profile image URLs as <code>http(s)</code> , bounds text fields, validates list fields, and rejects malformed <code>profileComplete</code> values. Frontend onboarding/profile/feed flows no longer send self-service center mutations.	New <code>app.test.ts</code> coverage rejects auth and legacy center self-assignment, oversized fields, and unsafe image URLs. Frontend typecheck/tests/export verify the UI fallout.
AE-F007	Partially fixed	Password reset now invalidates existing JWTs through the password-hash fingerprint. Full logout-triggered revocation still requires a token revocation store or per-user session version column.	Covered by password reset token-rotation tests. Residual logout revocation is tracked as follow-up.
AE-F008	Fixed	Public <code>userExistence</code> now returns a generic false response, public invite validation now returns a generic invalid response for inactive, expired, exhausted, or nonexistent codes, and invite-gated registration rejects missing invites before duplicate-user lookup.	New <code>app.test.ts</code> coverage asserts existing usernames are not disclosed through <code>userExistence</code> or no-invite gated registration.
AE-F009	Fixed	Email verification resend no longer mints duplicate active tokens. Password reset request no-ops while an unexpired active reset code already exists.	New <code>app.test.ts</code> and <code>passwordReset.test.ts</code> coverage verifies active-token dedupe.
AE-F010	Fixed	Event creation now requires coordinator/admin authority scoped to the creator's center, blocking cross-center event creation by non-admin coordinators.	Covered by event creation role/scope regressions in <code>app.test.ts</code> .
AE-F011	Fixed	Event creation validates ISO datetimes, coordinate ranges, URL schemes, category values, boolean fields, and point-of-contact length before insert.	Covered by invalid event creation payload regressions in <code>app.test.ts</code> .
AE-F012	Fixed	Creator-owned event updates now apply the same validation and center-scope checks as creation.	Covered by invalid owner update payload regressions in <code>app.test.ts</code> .
AE-F013	Fixed	Admin event updates now share the hardened validation path rather than accepting unsafe field values.	Covered by admin event update regressions in <code>app.test.ts</code> .
AE-F014	Fixed	Event management now requires current SEVAK+ authority, creator match, and center match. Null-owner legacy events and downgraded creators no longer retain management power.	Covered by legacy/null-owner and downgraded-creator regressions in <code>app.test.ts</code> .
AE-F015	Fixed	<code>requiresVerified</code> is persisted at event creation and enforced by both authenticated RSVP and guest RSVP endpoints.	Covered by verified-only RSVP regressions in <code>app.test.ts</code> .
AE-F016	Partially fixed	The spoofed-IP spam path is closed through the rate-limit fix, and verified-only events block guest RSVP. Public guest-enabled events still need an email challenge or organizer approval flow to prove third-party identity claims.	Covered by rate-limit and verified-only RSVP tests; guest identity proofing remains follow-up.
AE-F017	Fixed	Raw user event/group history endpoints now require self or admin. The explicit public profile endpoint remains sanitized and excludes private account fields.	New <code>app.test.ts</code> coverage blocks cross-user event/group history reads and permits admin reads.
AE-F018	Partially fixed	Legacy unpaginated event reads and center-specific public event reads are capped at 200 with SQL-level limits, and event registration state now returns 404 for missing events. <code>createdBy</code> remains in the event API for frontend owner-state behavior and should be split into a private event schema later.	New <code>app.test.ts</code> coverage verifies all-event and center-event list caps plus missing-event registration 404.

Post-Fix Test Results

Command	Result	Details
repo: git fetch --all --prune && git merge origin/main --no-edit	Passed	origin/main merged cleanly into v2 before validation.
packages/backend: bun run typecheck	Passed	tsc --noEmit completed without errors.
packages/backend: bunx vitest run src/__tests__/app.test.ts src/__tests__/passwordReset.test.ts src/__tests__/email.test.ts	Passed	3 test files passed, 268 tests passed.
packages/backend: bun run test	Passed	12 test files passed, 479 tests passed.
packages/frontend: bun run typecheck	Passed	tsc --noEmit completed without errors.
packages/frontend: bun run test	Passed	12 test files passed, 201 tests passed.
packages/frontend: bunx expo export --platform web	Passed	Expo web export completed; dist generated.
repo: SITEMAP_SKIP_NETWORK=1 bun scripts/generate-sitemap.cjs	Passed	Generated dist/sitemap.xml with 5 static URLs.

Findings Summary

ID	Severity	CVSS	Controls	Finding
AE-F001	Critical	9.8	2	Mutable email is used as an admin credential
AE-F002	Critical	9.1	3	Developer-email registration bypass grants admin-capable role
AE-F003	High	8.3	6	Inactive and suspended users remain fully authenticated
AE-F004	High	8.2	6	Auth and event abuse throttles trust spoofable IP headers
AE-F005	Low	3.7	10	Malformed JSON exposes internal parser errors across auth/event routes
AE-F006	Critical	9.0	5	Profile mutation lets users rewrite security-sensitive identity fields
AE-F007	High	8.1	3	Session lifecycle is stateless and logout does not revoke tokens
AE-F008	Medium	5.3	2	Unauthenticated account and invite state can be enumerated
AE-F009	Medium	6.8	2	Email verification and password reset can be spammed per account
AE-F010	High	8.3	2	Event creation is role-gated but not center-scoped
AE-F011	High	8.0	22	Event creation accepts unsafe or nonsensical field values
AE-F012	High	8.5	29	Event owner update path bypasses create-time validation
AE-F013	High	8.0	23	Admin event update path has a separate validation bypass
AE-F014	High	8.4	4	Legacy or downgraded creators retain event-management power
AE-F015	High	8.1	2	Event RSVP endpoints bypass frontend-only signup constraints
AE-F016	Medium	6.9	2	Guest RSVP accepts unverified third-party identity claims
AE-F017	Medium	6.5	3	Event attendance and profile history are visible by username
AE-F018	Medium	5.9	4	Public event reads are unbounded and expose management identifiers

All Confirmed Controls

Each row is a confirmed failing auth/event control. Related controls are grouped into fixable vulnerability groups in the detailed section.

ID	Severity	CVSS	Endpoint	Control Failure
AE-C001	Critical	9.8	PUT /api/auth/update-profile -> GET /api/admin/users	Normal user becomes admin by setting email to ADMIN_EMAIL
AE-C002	Critical	9.8	POST /api/auth/authenticate	Login by spoofed admin email returns attacker-controlled admin session
AE-C003	Critical	9.1	POST /api/auth/register	Invite-only registration still allows listed developer email without invite
AE-C004	Critical	9.1	GET /api/auth/verify	Developer self-registration receives admin-capable verificationLevel
AE-C005	Critical	9.1	GET /api/admin/users	Developer self-registration can call admin endpoint
AE-C006	High	8.3	GET /api/auth/verify	Inactive user token verifies successfully
AE-C007	High	8.3	POST /api/auth/refresh	Inactive user can refresh session
AE-C008	High	8.3	POST /api/addEvent	Inactive sevak can create event
AE-C009	High	8.3	GET /api/auth/verify	Suspended user token verifies successfully
AE-C010	High	8.3	POST /api/auth/refresh	Suspended user can refresh session
AE-C011	High	8.3	POST /api/addEvent	Suspended sevak can create event
AE-C012	High	8.2	/auth/authenticate	Login limiter bypassed with varied forwarding headers
AE-C013	High	8.2	/auth/register	Register limiter bypassed with varied forwarding headers
AE-C014	High	8.2	/auth/password-reset/request	Password reset request limiter bypassed with varied forwarding headers
AE-C015	High	8.2	/auth/password-reset/verify	Password reset verify limiter bypassed with varied forwarding headers
AE-C016	High	8.2	/auth/validate-invite-code	Invite-code validation limiter bypassed with varied forwarding headers
AE-C017	High	8.2	/auth/send-verification-email	Email verification send limiter bypassed with varied forwarding headers
AE-C018	Low	3.7	POST /auth/register	POST /auth/register leaks parser/internal error on malformed JSON
AE-C019	Low	3.7	POST /auth/authenticate	POST /auth/authenticate leaks parser/internal error on malformed JSON
AE-C021	Low	3.7	PUT /auth/update-profile	PUT /auth/update-profile leaks parser/internal error on malformed JSON
AE-C022	Low	3.7	POST /addEvent	POST /addEvent leaks parser/internal error on malformed JSON
AE-C023	Low	3.7	POST /updateEvent	POST /updateEvent leaks parser/internal error on malformed JSON
AE-C024	Low	3.7	POST /removeEvent	POST /removeEvent leaks parser/internal error on malformed JSON
AE-C025	Low	3.7	POST /attendEvent	POST /attendEvent leaks parser/internal error on malformed JSON
AE-C026	Low	3.7	POST /unattendEvent	POST /unattendEvent leaks parser/internal error on malformed JSON
AE-C027	Low	3.7	PUT /admin/events/:id	PUT /admin/events/:id leaks parser/internal error on malformed JSON
AE-C028	Low	3.7	POST /admin/users/:id/verify	POST /admin/users/:id/verify leaks parser/internal error on malformed JSON
AE-C029	High	8.1	PUT /api/auth/update-profile	Duplicate email can be assigned without verification
AE-C030	Medium	6.4	PUT /api/auth/update-profile	Invalid email string can be assigned to account
AE-C031	Critical	9.0	PUT /api/auth/update-profile	Unverified user can self-assign center through update-profile
AE-C032	Critical	9.0	POST /api/auth/complete-onboarding	Unverified user can self-assign center through complete-onboarding
AE-C033	High	8.0	PUT /api/auth/update-profile	Profile route stores oversized display fields and javascript image URL
AE-C034	High	8.1	POST /api/auth/deauthenticate -> GET /api/auth/verify	Logout/deauthenticate does not invalidate access token
AE-C035	High	8.1	POST /api/auth/refresh	Same refresh token can be replayed multiple times

ID	Severity	CVSS	Endpoint	Control Failure
AE-C036	Medium	6.5	POST /api/auth/refresh	Refresh endpoint has no visible rate limit
AE-C037	Medium	5.3	POST /api/userExistence	Public userExistence distinguishes valid accounts from missing accounts
AE-C038	Low	3.9	POST /api/auth/validate-invite-code	Invite validation reveals inactive/expired/exhausted/not-found states
AE-C039	Medium	6.8	POST /api/auth/password-reset/request	Password reset request spam creates repeated reset-code rows for one account
AE-C040	Medium	6.5	POST /api/auth/send-verification-email	Email verification resend creates multiple simultaneously valid tokens
AE-C041	High	8.3	POST /api/addEvent	Sevak for center A can create official event under center B
AE-C042	High	8.0	POST /api/addEvent	Sevak can create official event under unverified center
AE-C043	Medium	6.5	POST /api/addEvent	Create accepts empty title
AE-C044	Medium	6.5	POST /api/addEvent	Create accepts missing title
AE-C045	Medium	6.2	POST /api/addEvent	Create accepts invalid date string
AE-C046	Medium	6.2	POST /api/addEvent	Create accepts impossible calendar date
AE-C047	Medium	5.9	POST /api/addEvent	Create accepts past event date
AE-C048	Medium	6.5	POST /api/addEvent	Create accepts huge pointOfContact
AE-C049	Medium	5.8	POST /api/addEvent	Create accepts negative category
AE-C050	Medium	5.8	POST /api/addEvent	Create accepts huge category
AE-C051	Medium	5.8	POST /api/addEvent	Create accepts string category
AE-C052	Low	3.9	POST /api/addEvent	Create accepts boolean category
AE-C054	High	8.0	POST /api/addEvent	Create accepts externalUrl scheme javascript
AE-C055	High	8.0	POST /api/addEvent	Create accepts signupUrl scheme javascript
AE-C056	High	8.0	POST /api/addEvent	Create accepts image scheme javascript
AE-C057	High	8.0	POST /api/addEvent	Create accepts externalUrl scheme data
AE-C058	High	8.0	POST /api/addEvent	Create accepts signupUrl scheme data
AE-C059	High	8.0	POST /api/addEvent	Create accepts image scheme data
AE-C060	High	8.0	POST /api/addEvent	Create accepts externalUrl scheme file
AE-C061	High	8.0	POST /api/addEvent	Create accepts signupUrl scheme file
AE-C062	High	8.0	POST /api/addEvent	Create accepts image scheme file
AE-C063	High	8.0	POST /api/addEvent	Create accepts externalUrl scheme vbscript
AE-C064	High	8.0	POST /api/addEvent	Create accepts signupUrl scheme vbscript
AE-C065	High	8.0	POST /api/addEvent	Create accepts image scheme vbscript
AE-C066	High	8.5	POST /api/updateEvent	Owner update accepts cross-center move
AE-C067	Medium	6.2	POST /api/updateEvent	Owner update accepts invalid date string
AE-C068	Medium	6.2	POST /api/updateEvent	Owner update accepts impossible calendar date
AE-C069	Medium	5.9	POST /api/updateEvent	Owner update accepts past date
AE-C070	Medium	6.5	POST /api/updateEvent	Owner update accepts empty title
AE-C071	High	8.0	POST /api/updateEvent	Owner update accepts huge title
AE-C072	High	8.0	POST /api/updateEvent	Owner update accepts huge description

ID	Severity	CVSS	Endpoint	Control Failure
AE-C073	Medium	6.8	POST /api/updateEvent	Owner update accepts huge address
AE-C074	Medium	6.8	POST /api/updateEvent	Owner update accepts huge pointOfContact
AE-C075	High	8.0	POST /api/updateEvent	Owner update accepts latitude 999
AE-C076	High	8.0	POST /api/updateEvent	Owner update accepts longitude -999
AE-C077	Medium	6.4	POST /api/updateEvent	Owner update accepts partial numeric latitude string
AE-C078	Medium	6.4	POST /api/updateEvent	Owner update accepts partial numeric longitude string
AE-C079	Medium	5.8	POST /api/updateEvent	Owner update accepts negative category
AE-C080	Medium	5.8	POST /api/updateEvent	Owner update accepts huge category
AE-C081	Medium	5.8	POST /api/updateEvent	Owner update accepts string category
AE-C082	Medium	6.1	POST /api/updateEvent	Owner update accepts allowJanataSignup string false coerces true
AE-C083	High	8.5	POST /api/updateEvent	Owner update accepts externalUrl scheme javascript
AE-C084	High	8.5	POST /api/updateEvent	Owner update accepts signupUrl scheme javascript
AE-C085	High	8.0	POST /api/updateEvent	Owner update accepts image scheme javascript
AE-C086	High	8.5	POST /api/updateEvent	Owner update accepts externalUrl scheme data
AE-C087	High	8.5	POST /api/updateEvent	Owner update accepts signupUrl scheme data
AE-C088	High	8.0	POST /api/updateEvent	Owner update accepts image scheme data
AE-C089	High	8.5	POST /api/updateEvent	Owner update accepts externalUrl scheme file
AE-C090	High	8.5	POST /api/updateEvent	Owner update accepts signupUrl scheme file
AE-C091	High	8.0	POST /api/updateEvent	Owner update accepts image scheme file
AE-C092	High	8.5	POST /api/updateEvent	Owner update accepts externalUrl scheme vbscript
AE-C093	High	8.5	POST /api/updateEvent	Owner update accepts signupUrl scheme vbscript
AE-C094	High	8.0	POST /api/updateEvent	Owner update accepts image scheme vbscript
AE-C095	Medium	6.2	PUT /api/admin/events/:id	Admin update accepts invalid date string
AE-C096	Medium	5.9	PUT /api/admin/events/:id	Admin update accepts past date
AE-C097	Medium	6.5	PUT /api/admin/events/:id	Admin update accepts empty title
AE-C098	High	8.0	PUT /api/admin/events/:id	Admin update accepts huge title
AE-C099	High	8.0	PUT /api/admin/events/:id	Admin update accepts huge description
AE-C100	Medium	6.8	PUT /api/admin/events/:id	Admin update accepts huge address
AE-C101	Medium	6.8	PUT /api/admin/events/:id	Admin update accepts huge pointOfContact
AE-C102	Medium	5.8	PUT /api/admin/events/:id	Admin update accepts negative category
AE-C103	Medium	5.8	PUT /api/admin/events/:id	Admin update accepts huge category
AE-C104	Medium	5.8	PUT /api/admin/events/:id	Admin update accepts string category
AE-C105	Medium	6.1	PUT /api/admin/events/:id	Admin update accepts allowJanataSignup string false coerces true
AE-C106	High	8.0	PUT /api/admin/events/:id	Admin update accepts externalUrl scheme javascript
AE-C107	High	8.0	PUT /api/admin/events/:id	Admin update accepts signupUrl scheme javascript
AE-C108	High	8.0	PUT /api/admin/events/:id	Admin update accepts image scheme javascript
AE-C109	High	8.0	PUT /api/admin/events/:id	Admin update accepts externalUrl scheme data

ID	Severity	CVSS	Endpoint	Control Failure
AE-C110	High	8.0	PUT /api/admin/events/:id	Admin update accepts signUpUrl scheme data
AE-C111	High	8.0	PUT /api/admin/events/:id	Admin update accepts image scheme data
AE-C112	High	8.0	PUT /api/admin/events/:id	Admin update accepts externalUrl scheme file
AE-C113	High	8.0	PUT /api/admin/events/:id	Admin update accepts signUpUrl scheme file
AE-C114	High	8.0	PUT /api/admin/events/:id	Admin update accepts image scheme file
AE-C115	High	8.0	PUT /api/admin/events/:id	Admin update accepts externalUrl scheme vbscript
AE-C116	High	8.0	PUT /api/admin/events/:id	Admin update accepts signUpUrl scheme vbscript
AE-C117	High	8.0	PUT /api/admin/events/:id	Admin update accepts image scheme vbscript
AE-C118	High	8.4	POST /api/updateEvent	Normal member can edit null-owner legacy event
AE-C119	High	8.4	POST /api/updateEvent	Downgraded creator can still edit event
AE-C120	High	8.4	GET /api/events/:id/roster	Downgraded creator can still view guest roster PII
AE-C121	High	8.4	POST /api/removeEvent	Downgraded creator can still delete event
AE-C122	High	8.1	POST /api/attendEvent	Authenticated RSVP succeeds for external-only event with allowJanataSignup=false
AE-C123	High	8.1	POST /api/attendEventGuest	Guest RSVP succeeds for external-only event with allowJanataSignup=false
AE-C124	Medium	6.9	POST /api/attendEventGuest -> GET /api/events/:id/roster	Guest RSVP can store someone else email/name without mailbox proof
AE-C125	High	8.0	POST /api/attendEventGuest	Guest RSVP spam bypasses nominal limiter with varied headers
AE-C126	Medium	6.5	POST /api/getUserEvents	Any authenticated user can fetch another username event attendance via legacy POST
AE-C127	Medium	6.5	GET /api/profile/:username/events	Any authenticated user can fetch another username event attendance via profile route
AE-C128	Medium	6.0	GET /api/profile/:username/groups	Any authenticated user can fetch another username center group
AE-C129	Medium	5.9	GET /api/fetchAllEvents	fetchAllEvents defaults to unbounded public event dump
AE-C130	Medium	5.9	POST /api/fetchEventsByCenter	fetchEventsByCenter POST defaults to unbounded public event dump
AE-C131	Low	4.2	POST /api/fetchEvent	Public event payload exposes createdBy management user id
AE-C132	Low	3.5	GET /api/events/:id/registration	Registration state endpoint returns 200 for nonexistent event id

AE-F001 - Critical - CVSS 9.8 - Mutable email is used as an admin credential

Affected: PUT /api/auth/update-profile, POST /api/auth/authenticate, adminMiddleware

CWE: CWE-266 Incorrect Privilege Assignment

Root Cause

Admin status trusts users.email, while users can update email without ownership proof or uniqueness.

Recommended Fix

Remove email-string admin checks. Store immutable admin assignments server-side and require verified email-change workflow.

Fix Applied and Verification

Status: Fixed

Admin authorization now uses verification_level >= ADMIN_CUTOFF instead of mutable email identity. Self-service email changes are blocked outside a verified email-change flow.

Verification: Covered by backend app auth/admin tests and backend typecheck.

Reproduction Procedure

Run the harness command from the cover page, then inspect the listed control IDs in auth-event-findings.json. Each control stores endpoint, expected behavior, observed API response, and screenshot linkage.

ID	Severity	CVSS	Endpoint	Control Failure
AE-C001	Critical	9.8	PUT /api/auth/update-profile -> GET /api/admin/users	Normal user becomes admin by setting email to ADMIN_EMAIL
AE-C002	Critical	9.8	POST /api/auth/authenticate	Login by spoofed admin email returns attacker-controlled admin session

AE-F001 Screenshot Evidence

AE-F001: Mutable email is used as an admin credential

Local auth/events red-team proof. Tokens redacted. Generated 2026-06-30T01:38:06.469Z.

2 confirmed control failures

Control	Severity	CVSS	Endpoint	Observed failure
AE-C001	Critical	9.8	PUT /api/auth/update-profile -> GET /api/admin/users	Normal user becomes admin by setting email to ADMIN_EMAIL
AE-C002	Critical	9.8	POST /api/auth/authenticate	Login by spoofed admin email returns attacker-controlled admin session

Representative evidence

```
{
  "id": "AE-C001",
  "title": "Normal user becomes admin by setting email to ADMIN_EMAIL",
  "observed": {
    "attackerBefore": {
      "status": 403,
      "ok": false,
      "body": {
        "message": "Admin access required"
      }
    },
    "spoofAdmin": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Profile updated",
        "user": {
          "id": "2026c424-7389-4a18-8382-86fcd6dd3ee",
          "username": "ae.attacker@janata.local",
          "email": "chinmaya.janata@gmail.com",
          "firstName": "Attacker",
          "lastName": "AE",
          "dateOfBirth": null,
          "phoneNumber": null,
          "profileImage": null,
          "bio": null,
          "centerID": "ae-center-a",
          "points": 0,
          "isVerified": true,
          "verificationLevel": 45,
          "isActive": true,
          "profileComplete": true,
          "interests": null,
          "school": null,
          "work": null,
          "region": null,
          "lookingFor": null,
          "isSuspended": false,
          "suspendedAt": null,
          "suspendedUntil": null,
          "suspendedReason": null,
          "createdAt": "2026-06-30T01:37:29.678Z",
          "updatedAt": "2026-06-30T01:37:32.914Z"
        }
      }
    },
    "attackerAfter": {
      "status": 200,
      "ok": true,
      "body": {
        "user": {
          "id": "692aae48-272a-4c0b-958c-d266d7d93930",
          "username": "ae.guest.victim@example.test",
          "email": "ae.guest.victim@example.test",
          "firstName": "",
          "lastName": "",
          "dateOfBirth": null,
          "phoneNumber": null,
          "profileImage": null,
          "bio": null,
          "centerID": null,
          "points": 0,
          "isVerified": true,
          "verificationLevel": 45,
          "isActive": false,
          "profileComplete": false,
          "interests": null,
          "school": null,
          "work": null,
          "region": null,
          "lookingFor": null,
          "isSuspended": false,
          "suspendedAt": null,
          "suspendedUntil": null,
          "suspendedReason": null,
          "createdAt": "2026-06-30T01:37:29.718Z",
          "updatedAt": "2026-06-30T01:37:29.718Z"
        }
      }
    }
  },
  "total": 24,
  "limit": 1,
  "offset": 0
},
{
  "id": "AE-C002",
  "title": "Login by spoofed admin email returns attacker-controlled admin session",
  "observed": {
    "allUser": {
      "id": "2026c424-7389-4a18-8382-86fcd6dd3ee",
      "username": "ae.attacker@janata.local",
      "email": "chinmaya.janata@gmail.com",
      "firstName": "Attacker",
      "lastName": "AE",
      "dateOfBirth": null,
      "phoneNumber": null,
      "profileImage": null,
      "bio": null,
      "centerID": "ae-center-a",
      "points": 0,
      "isVerified": true,
      "verificationLevel": 45,
      "isActive": true,
      "profileComplete": true,
      "interests": null,
      "school": null,
      "work": null,
      "region": null,
      "lookingFor": null,
      "isSuspended": false,
      "suspendedAt": null,
      "suspendedUntil": null,
      "suspendedReason": null,
      "createdAt": "2026-06-30T01:37:29.678Z",
      "updatedAt": "2026-06-30T01:37:32.914Z"
    }
  }
}
```

```
"aliasAdmin": {  
  "status": 200,  
  "ok": true,  
  "body": {  
    "data": [  
      {  
        "id": "602aae49-272a-4c0b-958c-d206d7d93936",  
        "username": "ae.guest.victim@example.test",  
        "email": "ae.guest.victim@example.test",  
        "firstName": "",  
        "lastName": "",  
        "dateOfBirth": null,  
        "phoneNumber": null,  
        "profileImage": null,  
        "bio": null,  
        "centerID": null,  
        "points": 0,  
        "isVerified": true,  
      }  
    ]  
  }  
}
```

AE-F002 - Critical - CVSS 9.1 - Developer-email registration bypass grants admin-capable role

Affected: POST /api/auth/register

CWE: CWE-287 Improper Authentication

Root Cause

Public registration grants BRAHMACHARI when username matches DEVELOPER_EMAILS, without proving email ownership.

Recommended Fix

Disable the bypass outside local dev and provision developer roles through an authenticated admin flow.

Fix Applied and Verification

Status: Fixed

Invite-only registration requires a valid invite for normal, developer, and bootstrap addresses. Bootstrap/admin promotion is no longer available from email alone.

Verification: Covered by invite gate registration tests in app.test.ts.

Reproduction Procedure

Run the harness command from the cover page, then inspect the listed control IDs in auth-event-findings.json. Each control stores endpoint, expected behavior, observed API response, and screenshot linkage.

ID	Severity	CVSS	Endpoint	Control Failure
AE-C003	Critical	9.1	POST /api/auth/register	Invite-only registration still allows listed developer email without invite
AE-C004	Critical	9.1	GET /api/auth/verify	Developer self-registration receives admin-capable verificationLevel
AE-C005	Critical	9.1	GET /api/admin/users	Developer self-registration can call admin endpoint

AE-F002 Screenshot Evidence

AE-F002: Developer-email registration bypass grants admin-capable role

Local auth/events red-team proof. Tokens redacted. Generated 2026-06-30T01:38:06.971Z.

3 confirmed control failures

Control	Severity	CVSS	Endpoint	Observed failure
AE-C003	Critical	9.1	POST /api/auth/register	Invite-only registration still allows listed developer email without invite
AE-C004	Critical	9.1	GET /api/auth/verify	Developer self-registration receives admin-capable verificationLevel
AE-C005	Critical	9.1	GET /api/admin/users	Developer self-registration can call admin endpoint

Representative evidence

```
[
  {
    "id": "AE-C003",
    "title": "Invite-only registration still allows listed developer email without invite",
    "observed": {
      "status": 201,
      "ok": true,
      "body": {
        "message": "User registered successfully",
        "username": "sahanavasairamesh@gmail.com"
      }
    }
  },
  {
    "id": "AE-C004",
    "title": "Developer self-registration receives admin-capable verificationLevel",
    "observed": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Token is valid",
        "user": {
          "id": "d7c48309-b915-448b-8801-05ff8f320423",
          "username": "sahanavasairamesh@gmail.com",
          "email": "sahanavasairamesh@gmail.com",
          "firstName": "",
          "lastName": "",
          "dateOfBirth": null,
          "phoneNumber": null,
          "profileImage": null,
          "bio": null,
          "centerID": null,
          "points": 0,
          "isVerified": true,
          "verificationLevel": 100,
          "isActive": false,
          "profileComplete": false,
          "interests": null,
          "school": null,
          "work": null,
          "region": null,
          "lookingFor": null,
          "isSuspended": false,
          "suspendedAt": null,
          "suspendedUntil": null,
          "suspendedReason": null,
          "createdAt": "2026-06-30T01:37:33.008Z",
          "updatedAt": "2026-06-30T01:37:33.008Z"
        }
      }
    }
  },
  {
    "id": "AE-C005",
    "title": "Developer self-registration can call admin endpoint",
    "observed": {
      "status": 200,
      "ok": true,
      "body": {
        "data": [
          {
            "id": "d7c48309-b915-448b-8801-05ff8f320423",
            "username": "sahanavasairamesh@gmail.com",
            "email": "sahanavasairamesh@gmail.com",
            "firstName": "",
            "lastName": "",
            "dateOfBirth": null,
            "phoneNumber": null,
            "profileImage": null,
            "bio": null,
            "centerID": null,
            "points": 0,
            "isVerified": true,
            "verificationLevel": 100,
            "isActive": false,
            "profileComplete": false,
            "interests": null,
            "school": null,
            "work": null,
            "region": null,
            "lookingFor": null,
            "isSuspended": false,
            "suspendedAt": null,
            "suspendedUntil": null,
            "suspendedReason": null,
            "createdAt": "2026-06-30T01:37:33.008Z",
            "updatedAt": "2026-06-30T01:37:33.008Z"
          }
        ],
        "total": 25,
        "limit": 1,
        "offset": 0
      }
    }
  }
]
```

AE-F003 - High - CVSS 8.3 - Inactive and suspended users remain fully authenticated

Affected: POST /api/auth/authenticate, GET /api/auth/verify, POST /api/auth/refresh, event write routes

CWE: CWE-285 Improper Authorization

Root Cause

authMiddleware and login/refresh flows do not reject is_active=0 or suspended accounts.

Recommended Fix

Enforce active and non-suspended state on login, refresh, and every authenticated request.

Fix Applied and Verification

Status: Fixed

authMiddleware and auth routes now deny inactive and suspended accounts before returning authenticated data.

Verification: Covered by inactive/suspended auth regression tests in app.test.ts.

Reproduction Procedure

Run the harness command from the cover page, then inspect the listed control IDs in auth-event-findings.json. Each control stores endpoint, expected behavior, observed API response, and screenshot linkage.

ID	Severity	CVSS	Endpoint	Control Failure
AE-C006	High	8.3	GET /api/auth/verify	Inactive user token verifies successfully
AE-C007	High	8.3	POST /api/auth/refresh	Inactive user can refresh session
AE-C008	High	8.3	POST /api/addEvent	Inactive sevak can create event
AE-C009	High	8.3	GET /api/auth/verify	Suspended user token verifies successfully
AE-C010	High	8.3	POST /api/auth/refresh	Suspended user can refresh session
AE-C011	High	8.3	POST /api/addEvent	Suspended sevak can create event

AE-F003 Screenshot Evidence

AE-F003: Inactive and suspended users remain fully authenticated

Local auth/events red-team proof. Tokens redacted. Generated 2026-06-30T01:38:07.222Z.

6 confirmed control failures

Control	Severity	CVSS	Endpoint	Observed failure
AE-C006	High	8.3	GET /api/auth/verify	Inactive user token verifies successfully
AE-C007	High	8.3	POST /api/auth/refresh	Inactive user can refresh session
AE-C008	High	8.3	POST /api/addEvent	Inactive sevak can create event
AE-C009	High	8.3	GET /api/auth/verify	Suspended user token verifies successfully
AE-C010	High	8.3	POST /api/auth/refresh	Suspended user can refresh session
AE-C011	High	8.3	POST /api/addEvent	Suspended sevak can create event

Representative evidence

```
{
  "id": "AE-C006",
  "title": "Inactive user token verifies successfully",
  "observed": {
    "status": 200,
    "ok": true,
    "body": {
      "message": "Token is valid",
      "user": {
        "id": "1db70f5e-5419-457a-ae8d-8654023a11a3",
        "username": "ae.inactive.sevak@janata.local",
        "email": "ae.inactive.sevak@janata.local",
        "firstName": "Inactive",
        "lastName": "Sevak",
        "dateOfBirth": null,
        "phoneNumber": null,
        "profileImage": null,
        "bio": null,
        "centerID": "ae-center-a",
        "points": 0,
        "isVerified": true,
        "verificationLevel": 54,
        "isActive": false,
        "profileComplete": true,
        "interests": null,
        "school": null,
        "work": null,
        "region": null,
        "lookingFor": null,
        "isSuspended": false,
        "suspendedAt": null,
        "suspendedUntil": null,
        "suspendedReason": null,
        "createdAt": "2026-06-30T01:37:29.515Z",
        "updatedAt": "2026-06-30T01:37:29.515Z"
      }
    }
  }
},
{
  "id": "AE-C007",
  "title": "Inactive user can refresh session",
  "observed": {
    "status": 200,
    "ok": true,
    "body": {
      "message": "Token refreshed",
      "token": "[JWT REDACTED]",
      "refreshToken": "[JWT REDACTED]",
      "user": {
        "id": "1db70f5e-5419-457a-ae8d-8654023a11a3",
        "username": "ae.inactive.sevak@janata.local",
        "email": "ae.inactive.sevak@janata.local",
        "firstName": "Inactive",
        "lastName": "Sevak",
        "dateOfBirth": null,
        "phoneNumber": null,
        "profileImage": null,
        "bio": null,
        "centerID": "ae-center-a",
        "points": 0,
        "isVerified": true,
        "verificationLevel": 54,
        "isActive": false,
        "profileComplete": true,
        "interests": null,
        "school": null,
        "work": null,
        "region": null,
        "lookingFor": null,
        "isSuspended": false,
        "suspendedAt": null,
        "suspendedUntil": null,
        "suspendedReason": null,
        "createdAt": "2026-06-30T01:37:29.515Z",
        "updatedAt": "2026-06-30T01:37:29.515Z"
      }
    }
  }
},
{
  "id": "AE-C008",
  "title": "Inactive sevak can create event",
  "observed": {
    "status": 200,
    "ok": true,
    "body": {
      "id": "09ee6e16-2224-4bd9-9050-5aad978cd977",
      "tier": 0
    }
  }
},
{
  "id": "AE-C009",
  "title": "Suspended user token verifies successfully",
  "observed": {
    "status": 200,
    "ok": true,
    "body": {
      "message": "Token is valid",
      "user": {
        "id": "4ab5f97a-26d1-4c2b-a135-7b9e6ee8e82d",
        "username": "ae.suspended.sevak@janata.local",
        "email": "ae.suspended.sevak@janata.local",
        "firstName": "Suspended",
        "lastName": "Sevak",
        "dateOfBirth": null,
        "phoneNumber": null,
        "profileImage": null,
        "bio": null,
        "centerID": "ae-center-a",
        "points": 0,
        "isVerified": true,
        "verificationLevel": 54,
        "isActive": false,
        "profileComplete": true,
        "interests": null,
        "school": null,
        "work": null,
        "region": null,
        "lookingFor": null,
        "isSuspended": true,
        "suspendedAt": "2026-06-30T01:37:29.515Z",
        "suspendedUntil": "2026-06-30T01:37:29.515Z",
        "suspendedReason": "User is suspended"
      }
    }
  }
}
```

```

    "isVerified": true,
    "verificationLevel": 54,
    "isActive": true,
    "profileComplete": true,
    "interests": null,
    "school": null,
    "work": null,
    "region": null,
    "lookingFor": null,
    "isSuspended": true,
    "suspendedAt": "2026-06-30 01:37:32",
    "suspendedUntil": null,
    "suspendedReason": "local proof",
    "createdAt": "2026-06-30T01:37:29.581Z",
    "updatedAt": "2026-06-30T01:37:29.581Z"
  }
}
},
{
  "id": "AE-C010",
  "title": "Suspended user can refresh session",
  "observed": {
    "status": 200,
    "ok": true,
    "body": {
      "message": "Token refreshed",
      "token": "[JMT_REDACTED]",
      "refreshToken": "[JMT_REDACTED]",
      "user": {
        "id": "6b05f97e-26d1-4cbb-a135-7b0e6ee0e82d",
        "username": "ae.suspended.sevak@janata.local",
        "email": "ae.suspended."
      }
    }
  }
}
}

```


AE-F004 - High - CVSS 8.2 - Auth and event abuse throttles trust spoofable IP headers

Affected: rateLimit middleware on auth and event RSVP routes

CWE: CWE-348 Use of Less Trusted Source

Root Cause

The rate limiter uses request-supplied CF-Connecting-IP and X-Forwarded-For headers.

Recommended Fix

Use trusted platform request metadata only and add per-account/per-event throttles.

Fix Applied and Verification

Status: Fixed

Rate limiting no longer trusts spoofable X-Forwarded-For. It keys on Cloudflare's connecting IP when present, then host fallback in local tests.

Verification: Covered by backend app rate-limit regressions and full suite.

Reproduction Procedure

Run the harness command from the cover page, then inspect the listed control IDs in auth-event-findings.json. Each control stores endpoint, expected behavior, observed API response, and screenshot linkage.

ID	Severity	CVSS	Endpoint	Control Failure
AE-C012	High	8.2	/auth/authenticate	Login limiter bypassed with varied forwarding headers
AE-C013	High	8.2	/auth/register	Register limiter bypassed with varied forwarding headers
AE-C014	High	8.2	/auth/password-reset/request	Password reset request limiter bypassed with varied forwarding headers
AE-C015	High	8.2	/auth/password-reset/verify	Password reset verify limiter bypassed with varied forwarding headers
AE-C016	High	8.2	/auth/validate-invite-code	Invite-code validation limiter bypassed with varied forwarding headers
AE-C017	High	8.2	/auth/send-verification-email	Email verification send limiter bypassed with varied forwarding headers

AE-F004 Screenshot Evidence

AE-F004: Auth and event abuse throttles trust spoofable IP headers

Local auth/events red-team proof. Tokens redacted. Generated 2026-06-30T01:38:07.526Z.

6 confirmed control failures

Control	Severity	CVSS	Endpoint	Observed failure
AE-C012	High	8.2	/auth/authenticate	Login limiter bypassed with varied forwarding headers
AE-C013	High	8.2	/auth/register	Register limiter bypassed with varied forwarding headers
AE-C014	High	8.2	/auth/password-reset/request	Password reset request limiter bypassed with varied forwarding headers
AE-C015	High	8.2	/auth/password-reset/verify	Password reset verify limiter bypassed with varied forwarding headers
AE-C016	High	8.2	/auth/validate-invite-code	Invite-code validation limiter bypassed with varied forwarding headers
AE-C017	High	8.2	/auth/send-verification-email	Email verification send limiter bypassed with varied forwarding headers

Representative evidence

```
[
  {
    "id": "AE-C012",
    "title": "Login limiter bypassed with varied Forwarding headers",
    "observed": {
      "sameIpStatuses": [
        401,
        401,
        401,
        401,
        401,
        401,
        429
      ],
      "variedIpStatuses": [
        401,
        401,
        401,
        401,
        401,
        401,
        401,
        401
      ]
    }
  },
  {
    "id": "AE-C013",
    "title": "Register limiter bypassed with varied forwarding headers",
    "observed": {
      "sameIpStatuses": [
        403,
        403,
        403,
        403,
        403,
        429
      ],
      "variedIpStatuses": [
        403,
        403,
        403,
        403,
        403,
        403,
        403
      ]
    }
  },
  {
    "id": "AE-C014",
    "title": "Password reset request limiter bypassed with varied forwarding headers",
    "observed": {
      "sameIpStatuses": [
        200,
        200,
        200,
        200,
        200,
        429
      ],
      "variedIpStatuses": [
        200,
        200,
        200,
        200,
        200,
        200,
        200,
        200,
        200,
        200
      ]
    }
  },
  {
    "id": "AE-C015",
    "title": "Password reset verify limiter bypassed with varied forwarding headers",
    "observed": {
      "sameIpStatuses": [
        400,
        400,
        400,
        400,
        400,
        400,
        400,
        400,
        429
      ],
      "variedIpStatuses": [
        400,
        400,
        400,
        400,
        400,
        400,
        400,
        400,
        400,
        400,
        400
      ]
    }
  },
  {
    "id": "AE-C016",
    "title": "Invite-code validation limiter bypassed with varied forwarding headers",
    "observed": {
      "sameIpStatuses": [
        200,
```

[illegible]



AE-F005 - Low - CVSS 3.7 - Malformed JSON exposes internal parser errors across auth/event routes

Affected: Global error handler plus routes using c.req.json without local catch

CWE: CWE-209 Information Exposure Through Error Message

Root Cause

app.onError returns exception messages to the client.

Recommended Fix

Return generic error bodies externally and keep detailed parser errors in logs only.

Fix Applied and Verification

Status: Fixed

Malformed JSON and unexpected route failures are handled by generic API errors instead of returning internal parser/stack details.

Verification: Covered by malformed body and error handling regressions in app.test.ts and passwordReset.test.ts.

Reproduction Procedure

Run the harness command from the cover page, then inspect the listed control IDs in auth-event-findings.json. Each control stores endpoint, expected behavior, observed API response, and screenshot linkage.

ID	Severity	CVSS	Endpoint	Control Failure
AE-C018	Low	3.7	POST /auth/register	POST /auth/register leaks parser/internal error on malformed JSON
AE-C019	Low	3.7	POST /auth/authenticate	POST /auth/authenticate leaks parser/internal error on malformed JSON
AE-C021	Low	3.7	PUT /auth/update-profile	PUT /auth/update-profile leaks parser/internal error on malformed JSON
AE-C022	Low	3.7	POST /addEvent	POST /addEvent leaks parser/internal error on malformed JSON
AE-C023	Low	3.7	POST /updateEvent	POST /updateEvent leaks parser/internal error on malformed JSON
AE-C024	Low	3.7	POST /removeEvent	POST /removeEvent leaks parser/internal error on malformed JSON
AE-C025	Low	3.7	POST /attendEvent	POST /attendEvent leaks parser/internal error on malformed JSON
AE-C026	Low	3.7	POST /unattendEvent	POST /unattendEvent leaks parser/internal error on malformed JSON
AE-C027	Low	3.7	PUT /admin/events/:id	PUT /admin/events/:id leaks parser/internal error on malformed JSON
AE-C028	Low	3.7	POST /admin/users/:id/verify	POST /admin/users/:id/verify leaks parser/internal error on malformed JSON

AE-F005 Screenshot Evidence

AE-F005: Malformed JSON exposes internal parser errors across auth/event routes

Local auth/events red-team proof. Tokens redacted. Generated 2026-06-30T01:38:07.906Z.

10 confirmed control failures

Control	Severity	CVSS	Endpoint	Observed failure
AE-C018	Low	3.7	POST /auth/register	POST /auth/register leaks parser/internal error on malformed JSON
AE-C019	Low	3.7	POST /auth/authenticate	POST /auth/authenticate leaks parser/internal error on malformed JSON
AE-C021	Low	3.7	PUT /auth/update-profile	PUT /auth/update-profile leaks parser/internal error on malformed JSON
AE-C022	Low	3.7	POST /addEvent	POST /addEvent leaks parser/internal error on malformed JSON
AE-C023	Low	3.7	POST /updateEvent	POST /updateEvent leaks parser/internal error on malformed JSON
AE-C024	Low	3.7	POST /removeEvent	POST /removeEvent leaks parser/internal error on malformed JSON
AE-C025	Low	3.7	POST /attendEvent	POST /attendEvent leaks parser/internal error on malformed JSON
AE-C026	Low	3.7	POST /unattendEvent	POST /unattendEvent leaks parser/internal error on malformed JSON
AE-C027	Low	3.7	PUT /admin/events/:id	PUT /admin/events/:id leaks parser/internal error on malformed JSON
AE-C028	Low	3.7	POST /admin/users/:id/verify	POST /admin/users/:id/verify leaks parser/internal error on malformed JSON

Representative evidence

```
[
  {
    "id": "AE-C018",
    "title": "POST /auth/register leaks parser/internal error on malformed JSON",
    "observed": {
      "status": 500,
      "ok": false,
      "body": {
        "message": "Internal server error",
        "error": "Unexpected end of JSON input"
      }
    }
  },
  {
    "id": "AE-C019",
    "title": "POST /auth/authenticate leaks parser/internal error on malformed JSON",
    "observed": {
      "status": 500,
      "ok": false,
      "body": {
        "message": "Internal server error",
        "error": "Unexpected end of JSON input"
      }
    }
  },
  {
    "id": "AE-C021",
    "title": "PUT /auth/update-profile leaks parser/internal error on malformed JSON",
    "observed": {
      "status": 500,
      "ok": false,
      "body": {
        "message": "Internal server error",
        "error": "Unexpected end of JSON input"
      }
    }
  },
  {
    "id": "AE-C022",
    "title": "POST /addEvent leaks parser/internal error on malformed JSON",
    "observed": {
      "status": 500,
      "ok": false,
      "body": {
        "message": "Internal server error",
        "error": "Unexpected end of JSON input"
      }
    }
  },
  {
    "id": "AE-C023",
    "title": "POST /updateEvent leaks parser/internal error on malformed JSON",
    "observed": {
      "status": 500,
      "ok": false,
      "body": {
        "message": "Internal server error",
        "error": "Unexpected end of JSON input"
      }
    }
  },
  {
    "id": "AE-C024",
    "title": "POST /removeEvent leaks parser/internal error on malformed JSON",
    "observed": {
      "status": 500,
      "ok": false,
      "body": {
        "message": "Internal server error",
        "error": "Unexpected end of JSON input"
      }
    }
  }
]
```

AE-F006 - Critical - CVSS 9.0 - Profile mutation lets users rewrite security-sensitive identity fields

Affected: PUT /api/auth/update-profile, POST /api/auth/complete-onboarding

CWE: CWE-639 Authorization Bypass Through User-Controlled Key

Root Cause

Self-service profile routes write email, center_id, and profile trust fields directly.

Recommended Fix

Split profile display fields from trust fields; require verified workflows or admin approval for email and center membership.

Fix Applied and Verification

Status: Fixed

Profile mutation now blocks email changes, rejects self-service center reassignment across auth and legacy profile routes, validates profile image URLs as http(s), bounds text fields, validates list fields, and rejects malformed profileComplete values. Frontend onboarding/profile/feed flows no longer send self-service center mutations.

Verification: New app.test.ts coverage rejects auth and legacy center self-assignment, oversized fields, and unsafe image URLs. Frontend typecheck/tests/export verify the UI fallout.

Reproduction Procedure

Run the harness command from the cover page, then inspect the listed control IDs in auth-event-findings.json. Each control stores endpoint, expected behavior, observed API response, and screenshot linkage.

ID	Severity	CVSS	Endpoint	Control Failure
AE-C029	High	8.1	PUT /api/auth/update-profile	Duplicate email can be assigned without verification
AE-C030	Medium	6.4	PUT /api/auth/update-profile	Invalid email string can be assigned to account
AE-C031	Critical	9.0	PUT /api/auth/update-profile	Unverified user can self-assign center through update-profile
AE-C032	Critical	9.0	POST /api/auth/complete-onboarding	Unverified user can self-assign center through complete-onboarding
AE-C033	High	8.0	PUT /api/auth/update-profile	Profile route stores oversized display fields and javascript image URL

AE-F006 Screenshot Evidence

AE-F006: Profile mutation lets users rewrite security-sensitive identity fields

Local auth/events red-team proof. Tokens redacted. Generated 2026-06-30T01:38:08.161Z.

5 confirmed control failures

Control	Severity	CVSS	Endpoint	Observed failure
AE-C029	High	8.1	PUT /api/auth/update-profile	Duplicate email can be assigned without verification
AE-C030	Medium	6.4	PUT /api/auth/update-profile	Invalid email string can be assigned to account
AE-C031	Critical	9.0	PUT /api/auth/update-profile	Unverified user can self-assign center through update-profile
AE-C032	Critical	9.0	POST /api/auth/complete-onboarding	Unverified user can self-assign center through complete-onboarding
AE-C033	High	8.0	PUT /api/auth/update-profile	Profile route stores oversized display fields and javascript image URL

Representative evidence

```
[
  {
    "id": "AE-C029",
    "title": "Duplicate email can be assigned without verification",
    "observed": {
      "duplicateEmail": {
        "status": 200,
        "ok": true,
        "body": {
          "message": "Profile updated",
          "user": {
            "id": "0b11d1c1-0771-4679-9352-f3b20411d42",
            "username": "ae.member@janata.local",
            "email": "ae.target@janata.local",
            "firstName": "Member",
            "lastName": "AE",
            "dateOfBirth": null,
            "phoneNumber": null,
            "profileImage": null,
            "bio": null,
            "centerID": "ae-center-a",
            "points": 0,
            "isVerified": true,
            "verificationLevel": 45,
            "isActive": true,
            "profileComplete": true,
            "interests": null,
            "school": null,
            "work": null,
            "region": null,
            "lookingFor": null,
            "isSuspended": false,
            "suspendedAt": null,
            "suspendedUntil": null,
            "suspendedReason": null,
            "createdAt": "2026-06-30T01:37:29.265Z",
            "updatedAt": "2026-06-30T01:37:40.503Z"
          }
        }
      },
      "duplicateEmails": [
        {
          "username": "ae.member@janata.local",
          "email": "ae.target@janata.local"
        },
        {
          "username": "ae.target@janata.local",
          "email": "ae.target@janata.local"
        }
      ]
    }
  },
  {
    "id": "AE-C030",
    "title": "Invalid email string can be assigned to account",
    "observed": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Profile updated",
        "user": {
          "id": "0d438a5-7c50-4fbd-8c8b-63dc3d0c2d0b",
          "username": "ae.member@janata.local",
          "email": "not-an-email",
          "firstName": "Member",
          "lastName": "AE",
          "dateOfBirth": null,
          "phoneNumber": null,
          "profileImage": null,
          "bio": null,
          "centerID": "ae-center-b",
          "points": 0,
          "isVerified": true,
          "verificationLevel": 45,
          "isActive": true,
          "profileComplete": true,
          "interests": null,
          "school": null,
          "work": null,
          "region": null,
          "lookingFor": null,
          "isSuspended": false,
          "suspendedAt": null,
          "suspendedUntil": null,
          "suspendedReason": null,
          "createdAt": "2026-06-30T01:37:29.265Z",
          "updatedAt": "2026-06-30T01:37:40.524Z"
        }
      }
    }
  },
  {
    "id": "AE-C031",
    "title": "Unverified user can self-assign center through update-profile",
    "observed": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Profile updated",
        "user": {
          "id": "0e03b18b-c15d-4a0b-8a5d-c56c62235201",
          "username": "ae.unverified@janata.local",
          "email": "ae.unverified@janata.local",
          "firstName": "Unverified",
          "lastName": "AE",
          "dateOfBirth": null,
          "phoneNumber": null,
          "profileImage": null,
          "bio": null,
          "centerID": "ae-center-b",
          "points": 0,
          "isVerified": false,
          "verificationLevel": 30,
          "isActive": true,
          "profileComplete": true
        }
      }
    }
  }
]
```



```
    "interests": null,  
    "school": null,  
    "work": null,  
    "region": null,  
    "lookingFor": null,  
    "isSuspended": false,  
    "suspendedAt": null,  
    "suspendedUntil": null,  
    "suspendedReason": null,  
    "createdAt": "2020-06-30T01:37:29.332Z",  
    "updatedAt": "2020-06-30T01:37:40.545Z"  
  }  
}  
},  
{  
  "id": "AE-C032",  
  "title": "Unverified user can self-assign center through complete-onboarding",  
  "observed": {  
    "status": 200,  
    "ok": true,  
    "body": {  
      "message": "Profile completed successfully",  
      "user": {  
        "id": "de63b100-c136-4a8b-8ad5-c56c62235201",  
        "username": "ae.unverified@janata.local",  
        "email": "ae.unverified@janata.local",  
        "firstN
```

AE-F007 - High - CVSS 8.1 - Session lifecycle is stateless and logout does not revoke tokens

Affected: POST /api/auth/deauthenticate, POST /api/auth/refresh

CWE: CWE-613 Insufficient Session Expiration

Root Cause

Logout is a no-op and refresh tokens can be replayed until expiry or password rotation.

Recommended Fix

Store refresh-token identifiers, rotate on use, revoke on logout, and rate-limit refresh attempts.

Fix Applied and Verification

Status: Partially fixed

Password reset now invalidates existing JWTs through the password-hash fingerprint. Full logout-triggered revocation still requires a token revocation store or per-user session version column.

Verification: Covered by password reset token-rotation tests. Residual logout revocation is tracked as follow-up.

Reproduction Procedure

Run the harness command from the cover page, then inspect the listed control IDs in auth-event-findings.json. Each control stores endpoint, expected behavior, observed API response, and screenshot linkage.

ID	Severity	CVSS	Endpoint	Control Failure
AE-C034	High	8.1	POST /api/auth/deauthenticate -> GET /api/auth/verify	Logout/deauthenticate does not invalidate access token
AE-C035	High	8.1	POST /api/auth/refresh	Same refresh token can be replayed multiple times
AE-C036	Medium	6.5	POST /api/auth/refresh	Refresh endpoint has no visible rate limit

AE-F007 Screenshot Evidence

AE-F007: Session lifecycle is stateless and logout does not revoke tokens

Local auth/events red-team proof. Tokens redacted. Generated 2026-06-30T01:38:08.482Z.

3 confirmed control failures

Control	Severity	CVSS	Endpoint	Observed failure
AE-C034	High	8.1	POST /api/auth/deauthenticate -> GET /api/auth/verify	Logout/deauthenticate does not invalidate access token
AE-C035	High	8.1	POST /api/auth/refresh	Same refresh token can be replayed multiple times
AE-C036	Medium	6.5	POST /api/auth/refresh	Refresh endpoint has no visible rate limit

Representative evidence

```
{
  "id": "AE-0034",
  "title": "Logout/deauthenticate does not invalidate access token",
  "observed": {
    "logout": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Deauthentication successful!"
      }
    },
    "verifyAfterLogout": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Token is valid",
        "user": {
          "id": "03a131e1-8071-4675-9352-r35c29411d42",
          "username": "ae.membera@janata.local",
          "email": "ae.target@janata.local",
          "firstName":

```

(The page contains a large rectangular area filled with dense, illegible horizontal lines, likely representing a corrupted or redacted section of text.)

AE-F008 - Medium - CVSS 5.3 - Unauthenticated account and invite state can be enumerated

Affected: POST /api/userExistence, POST /api/auth/validate-invite-code

CWE: CWE-203 Observable Discrepancy

Root Cause

Public endpoints return exact existence and invite-state differences.

Recommended Fix

Remove user existence endpoint and normalize invite validation responses where possible.

Fix Applied and Verification

Status: Fixed

Public userExistence now returns a generic false response, public invite validation now returns a generic invalid response for inactive, expired, exhausted, or nonexistent codes, and invite-gated registration rejects missing invites before duplicate-user lookup.

Verification: New app.test.ts coverage asserts existing usernames are not disclosed through userExistence or no-invite gated registration.

Reproduction Procedure

Run the harness command from the cover page, then inspect the listed control IDs in auth-event-findings.json. Each control stores endpoint, expected behavior, observed API response, and screenshot linkage.

ID	Severity	CVSS	Endpoint	Control Failure
AE-C037	Medium	5.3	POST /api/userExistence	Public userExistence distinguishes valid accounts from missing accounts
AE-C038	Low	3.9	POST /api/auth/validate-invite-code	Invite validation reveals inactive/expired/exhausted/not-found states

AE-F008 Screenshot Evidence

AE-F008: Unauthenticated account and invite state can be enumerated

Local auth/events red-team proof. Tokens redacted. Generated 2026-06-30T01:38:08.679Z.

2 confirmed control failures

Control	Severity	CVSS	Endpoint	Observed failure
AE-C037	Medium	5.3	POST /api/userExistence	Public userExistence distinguishes valid accounts from missing accounts
AE-C038	Low	3.9	POST /api/auth/validate-invite-code	Invite validation reveals inactive/expired/exhausted/not-found states

Representative evidence

```
{
  {
    "id": "AE-C037",
    "title": "Public userExistence distinguishes valid accounts from missing accounts",
    "observed": {
      "enumKnown": {
        "status": 200,
        "ok": true,
        "body": {
          "existence": true
        }
      },
      "enumUnknown": {
        "status": 200,
        "ok": true,
        "body": {
          "existence": false
        }
      }
    }
  },
  {
    "id": "AE-C038",
    "title": "Invite validation reveals inactive/expired/exhausted/not-found states",
    "observed": {
      "AE-INACTIVE": {
        "status": 200,
        "ok": true,
        "body": {
          "valid": false,
          "error": "This invite link has been deactivated",
          "reason": "inactive"
        }
      },
      "AE-EXPIRED": {
        "status": 200,
        "ok": true,
        "body": {
          "valid": false,
          "error": "This invite link has expired",
          "reason": "expired"
        }
      },
      "AE-EXHAUSTED": {
        "status": 200,
        "ok": true,
        "body": {
          "valid": false,
          "error": "This invite link has reached its maximum number of uses",
          "reason": "exhausted"
        }
      },
      "AE-MISSING": {
        "status": 200,
        "ok": true,
        "body": {
          "valid": false,
          "error": "Invalid or inactive invite code",
          "reason": "not_found"
        }
      }
    }
  }
}
```

AE-F009 - Medium - CVSS 6.8 - Email verification and password reset can be spammed per account

Affected: POST /api/auth/send-verification-email, POST /api/auth/password-reset/request

CWE: CWE-770 Allocation of Resources Without Limits

Root Cause

Flows are throttled only by spoofable IP, not by account/email, and create multiple server-side tokens.

Recommended Fix

Add per-account cooldowns, invalidate or reuse email-verification tokens, and alert on repeated reset requests.

Fix Applied and Verification

Status: Fixed

Email verification resend no longer mints duplicate active tokens. Password reset request no-ops while an unexpired active reset code already exists.

Verification: New app.test.ts and passwordReset.test.ts coverage verifies active-token dedupe.

Reproduction Procedure

Run the harness command from the cover page, then inspect the listed control IDs in auth-event-findings.json. Each control stores endpoint, expected behavior, observed API response, and screenshot linkage.

ID	Severity	CVSS	Endpoint	Control Failure
AE-C039	Medium	6.8	POST /api/auth/password-reset/request	Password reset request spam creates repeated reset-code rows for one account
AE-C040	Medium	6.5	POST /api/auth/send-verification-email	Email verification resend creates multiple simultaneously valid tokens

AE-F009 Screenshot Evidence

AE-F009: Email verification and password reset can be spammed per account

Local auth/events red-team proof. Tokens redacted. Generated 2026-06-30T01:38:08.892Z.

2 confirmed control failures

Control	Severity	CVSS	Endpoint	Observed failure
AE-C039	Medium	6.8	POST /api/auth/password-reset/request	Password reset request spam creates repeated reset-code rows for one account
AE-C040	Medium	6.5	POST /api/auth/send-verification-email	Email verification resend creates multiple simultaneously valid tokens.

Representative evidence

```
[
  {
    "id": "AE-C039",
    "title": "Password reset request spam creates repeated reset-code rows for one account",
    "observed": {
      "resetBefore": 13,
      "statuses": [
        200,
        200,
        200,
        200,
        200,
        200,
        200,
        200,
        200
      ],
      "resetAfter": {
        "count": 21,
        "active": 1
      }
    }
  },
  {
    "id": "AE-C040",
    "title": "Email verification resend creates multiple simultaneously valid tokens",
    "observed": {
      "emailTokensBefore": 10,
      "statuses": [
        {
          "status": 200,
          "body": {
            "message": "Verification email sent"
          }
        },
        {
          "status": 200,
          "body": {
            "message": "Verification email sent"
          }
        },
        {
          "status": 200,
          "body": {
            "message": "Verification email sent"
          }
        },
        {
          "status": 200,
          "body": {
            "message": "Verification email sent"
          }
        },
        {
          "status": 200,
          "body": {
            "message": "Verification email sent"
          }
        }
      ],
      "emailTokensAfter": {
        "count": 16,
        "active": 16
      }
    }
  }
]
```

AE-F010 - High - CVSS 8.3 - Event creation is role-gated but not center-scoped

Affected: POST /api/addEvent

CWE: CWE-863 Incorrect Authorization

Root Cause

A sevak can create official events for any center without proving local coordinator scope.

Recommended Fix

Scope event creation to centers the coordinator manages, or require admin approval for cross-center events.

Fix Applied and Verification

Status: Fixed

Event creation now requires coordinator/admin authority scoped to the creator's center, blocking cross-center event creation by non-admin coordinators.

Verification: Covered by event creation role/scope regressions in app.test.ts.

Reproduction Procedure

Run the harness command from the cover page, then inspect the listed control IDs in auth-event-findings.json. Each control stores endpoint, expected behavior, observed API response, and screenshot linkage.

ID	Severity	CVSS	Endpoint	Control Failure
AE-C041	High	8.3	POST /api/addEvent	Sevak for center A can create official event under center B
AE-C042	High	8.0	POST /api/addEvent	Sevak can create official event under unverified center

AE-F010 Screenshot Evidence

AE-F010: Event creation is role-gated but not center-scoped

Local auth/events red-team proof. Tokens redacted. Generated 2026-06-30T01:38:09.100Z.

2 confirmed control failures

Control	Severity	CVSS	Endpoint	Observed failure
AE-C041	High	8.3	POST /api/addEvent	Sevak for center A can create official event under center B
AE-C042	High	8.0	POST /api/addEvent	Sevak can create official event under unverified center

Representative evidence

```
{
  "id": "AE-C041",
  "title": "Sevak for center A can create official event under center B",
  "observed": {
    "crossCenter": {
      "status": 200,
      "ok": true,
      "body": {
        "id": "3da42364-3c5b-47b7-b0b0-99706d3aba78",
        "tier": 0
      }
    },
    "crossFetch": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Success",
        "event": {
          "eventID": "3da42364-3c5b-47b7-b0b0-99706d3aba78",
          "title": "AE cross-center create",
          "description": "Local auth/events proof",
          "date": "2026-09-01T12:00:00.000Z",
          "endDate": null,
          "isRecurring": false,
          "latitude": 37.3349,
          "longitude": -121.8881,
          "address": "Local red-team proof",
          "centerID": "ae-center-b",
          "tier": 0,
          "peopleAttending": 0,
          "pointOfContact": null,
          "image": null,
          "category": 01,
          "createdBy": "3442d255-10b6-4139-aa9a-bdbf99f7fd46",
          "externalUrl": null,
          "signupUrl": null,
          "allowJanataSignup": false,
          "isOfficial": true,
          "requiresVerified": false,
          "createdAt": "2026-06-30T01:37:56.388Z",
          "updatedAt": "2026-06-30T01:37:56.406Z"
        }
      }
    }
  }
},
{
  "id": "AE-C042",
  "title": "Sevak can create official event under unverified center",
  "observed": {
    "unverifiedCenter": {
      "status": 200,
      "ok": true,
      "body": {
        "id": "3a2cf0a7-5a5d-47ab-ac0c-45c449c787fe",
        "tier": 0
      }
    },
    "unverifiedCenterFetch": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Success",
        "event": {
          "eventID": "3a2cf0a7-5a5d-47ab-ac0c-45c449c787fe",
          "title": "AE unverified center create",
          "description": "Local auth/events proof",
          "date": "2026-09-01T12:00:00.000Z",
          "endDate": null,
          "isRecurring": false,
          "latitude": 37.3349,
          "longitude": -121.8881,
          "address": "Local red-team proof",
          "centerID": "ae-center-unverified",
          "tier": 0,
          "peopleAttending": 0,
          "pointOfContact": null,
          "image": null,
          "category": 01,
          "createdBy": "3442d255-10b6-4139-aa9a-bdbf99f7fd46",
          "externalUrl": null,
          "signupUrl": null,
          "allowJanataSignup": false,
          "isOfficial": true,
          "requiresVerified": false,
          "createdAt": "2026-06-30T01:37:56.446Z",
          "updatedAt": "2026-06-30T01:37:56.469Z"
        }
      }
    }
  }
}
}
```

AE-F011 - High - CVSS 8.0 - Event creation accepts unsafe or nonsensical field values

Affected: POST /api/addEvent

CWE: CWE-20 Improper Input Validation

Root Cause

Create validation checks only a subset of fields and treats URL fields as length-bounded strings.

Recommended Fix

Use a strict shared event schema with URL scheme allowlists, date validation, category enum checks, and bounded optional fields.

Fix Applied and Verification

Status: Fixed

Event creation validates ISO datetimes, coordinate ranges, URL schemes, category values, boolean fields, and point-of-contact length before insert.

Verification: Covered by invalid event creation payload regressions in app.test.ts.

Reproduction Procedure

Run the harness command from the cover page, then inspect the listed control IDs in auth-event-findings.json. Each control stores endpoint, expected behavior, observed API response, and screenshot linkage.

ID	Severity	CVSS	Endpoint	Control Failure
AE-C043	Medium	6.5	POST /api/addEvent	Create accepts empty title
AE-C044	Medium	6.5	POST /api/addEvent	Create accepts missing title
AE-C045	Medium	6.2	POST /api/addEvent	Create accepts invalid date string
AE-C046	Medium	6.2	POST /api/addEvent	Create accepts impossible calendar date
AE-C047	Medium	5.9	POST /api/addEvent	Create accepts past event date
AE-C048	Medium	6.5	POST /api/addEvent	Create accepts huge pointOfContact
AE-C049	Medium	5.8	POST /api/addEvent	Create accepts negative category
AE-C050	Medium	5.8	POST /api/addEvent	Create accepts huge category
AE-C051	Medium	5.8	POST /api/addEvent	Create accepts string category
AE-C052	Low	3.9	POST /api/addEvent	Create accepts boolean category
AE-C054	High	8.0	POST /api/addEvent	Create accepts externalUrl scheme javascript
AE-C055	High	8.0	POST /api/addEvent	Create accepts signupUrl scheme javascript
AE-C056	High	8.0	POST /api/addEvent	Create accepts image scheme javascript
AE-C057	High	8.0	POST /api/addEvent	Create accepts externalUrl scheme data
AE-C058	High	8.0	POST /api/addEvent	Create accepts signupUrl scheme data
AE-C059	High	8.0	POST /api/addEvent	Create accepts image scheme data
AE-C060	High	8.0	POST /api/addEvent	Create accepts externalUrl scheme file
AE-C061	High	8.0	POST /api/addEvent	Create accepts signupUrl scheme file
AE-C062	High	8.0	POST /api/addEvent	Create accepts image scheme file
AE-C063	High	8.0	POST /api/addEvent	Create accepts externalUrl scheme vbscript
AE-C064	High	8.0	POST /api/addEvent	Create accepts signupUrl scheme vbscript

ID	Severity	CVSS	Endpoint	Control Failure
AE-C065	High	8.0	POST /api/addEvent	Create accepts image scheme vbscript

AE-F011 Screenshot Evidence

AE-F011: Event creation accepts unsafe or nonsensical field values

Local auth/events red-team proof. Tokens redacted. Generated 2026-06-30T01:38:09.341Z.

22 confirmed control failures

Control	Severity	CVSS	Endpoint	Observed failure
AE-C043	Medium	6.5	POST /api/addEvent	Create accepts empty title
AE-C044	Medium	6.5	POST /api/addEvent	Create accepts missing title
AE-C045	Medium	6.2	POST /api/addEvent	Create accepts invalid date string
AE-C046	Medium	6.2	POST /api/addEvent	Create accepts impossible calendar date
AE-C047	Medium	5.9	POST /api/addEvent	Create accepts past event date
AE-C048	Medium	6.5	POST /api/addEvent	Create accepts huge pointOfContact
AE-C049	Medium	5.8	POST /api/addEvent	Create accepts negative category
AE-C050	Medium	5.8	POST /api/addEvent	Create accepts huge category
AE-C051	Medium	5.8	POST /api/addEvent	Create accepts string category
AE-C052	Low	3.9	POST /api/addEvent	Create accepts boolean category
AE-C054	High	8.0	POST /api/addEvent	Create accepts externalUrl scheme javascript
AE-C055	High	8.0	POST /api/addEvent	Create accepts signUpUrl scheme javascript
AE-C056	High	8.0	POST /api/addEvent	Create accepts image scheme javascript
AE-C057	High	8.0	POST /api/addEvent	Create accepts externalUrl scheme data
AE-C058	High	8.0	POST /api/addEvent	Create accepts signUpUrl scheme data
AE-C059	High	8.0	POST /api/addEvent	Create accepts image scheme data
AE-C060	High	8.0	POST /api/addEvent	Create accepts externalUrl scheme file
AE-C061	High	8.0	POST /api/addEvent	Create accepts signUpUrl scheme file
AE-C062	High	8.0	POST /api/addEvent	Create accepts image scheme file
AE-C063	High	8.0	POST /api/addEvent	Create accepts externalUrl scheme vbscript
AE-C064	High	8.0	POST /api/addEvent	Create accepts signUpUrl scheme vbscript
AE-C065	High	8.0	POST /api/addEvent	Create accepts image scheme vbscript

Representative evidence

```
{
  "id": "AE-C043",
  "title": "Create accepts empty title",
  "observed": {
    "create": {
      "status": 200,
      "ok": true,
      "body": {
        "id": "5f8e10f9-3458-48c4-b561-188852ad7fb2",
        "tier": 0
      }
    },
    "fetched": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Success",
        "event": {
          "eventId": "5f8e10f9-3458-48c4-b561-188852ad7fb2",
          "title": "",
          "description": "Local auth/events proof",
          "date": "2026-09-01T12:00:00.000Z",
          "endDate": null,
          "isRecurring": false,
          "latitude": 37.3349,
          "longitude": -121.8881,
          "address": "Local red-team proof",
          "centerId": "ae-center-a",
          "tier": 0,
          "peopleAttending": 0,
          "pointOfContact": null,
          "image": null,
          "category": 01,
          "createdBy": "3442d255-10b6-4139-aa9a-bdbf99f7f646",
          "externalUrl": null,
          "signUpUrl": null,
          "allowJanataSignup": false,
          "isOfficial": true,
          "requireVerified": false,
          "createdAt": "2026-06-30T01:37:56.492Z",
          "updatedAt": "2026-06-30T01:37:56.506Z"
        }
      }
    }
  }
},
{
  "id": "AE-C044",
  "title": "Create accepts missing title",
  "observed": {
    "create": {
      "status": 200,
      "ok": true,
      "body": {
        "id": "8411e435-4e15-4c24-b459-020e244618ed",
        "tier": 0
      }
    },
    "fetched": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Success",
        "event": {
          "eventId": "8411e435-4e15-4c24-b459-020e244618ed",
          "title": "",
          "description": "Local auth/events proof",
          "date": "2026-09-01T12:00:00.000Z",
          "endDate": null,
          "isRecurring": false,
          "latitude": 37.3349,
          "longitude": -121.8881,
          "address": "Local red-team proof",
          "centerId": "ae-center-a",
          "tier": 0,
          "peopleAttending": 0,
          "pointOfContact": null,
          "image": null,
          "category": 01,
          "createdBy": "3442d255-10b6-4139-aa9a-bdbf99f7f646",
          "externalUrl": null,
          "signUpUrl": null,
          "allowJanataSignup": false,
          "isOfficial": true
        }
      }
    }
  }
}
```

```

      "requiresVerified": false,
      "createdAt": "2026-06-30T01:37:56.563Z",
      "updatedAt": "2026-06-30T01:37:56.574Z"
    }
  },
  {
    "id": "AE-C045",
    "title": "Create accepts invalid date string",
    "observed": {
      "create": {
        "status": 200,
        "ok": true,
        "body": {
          "id": "25dc4b45-bf3b-4b92-8771-aea70349f5bd",
          "tier": 0
        }
      },
      "fetched": {
        "status": 200,
        "ok": true,
        "body": {
          "message": "Success",
          "event": {
            "eventId": "25dc4b45-bf3b-4b92-8771-aea70349f5bd",
            "title": "AE create invalid date string",
            "description": "Local auth/events proof",
            "date": "not-a-date",
            "endDate": null,
            "isRecurring": false,
            "latitude": 37.3349,
            "longitude": -121.8881,
            "address": "Local red-team proof",
            "centerID": "ae-center-a",
            "tier": 0,
            "peopleAttending": 0,
            "pointOfContact": null,
            "image": null,
            "category": 91,
            "createdBy": "3442d255-10b6-4139-aa9a-bdbf99f7fd46",
            "externalUrl": null,
            "signupUrl": null,
            "allowJanataSignup": false,
            "isOfficial": true,
            "requiresVerified": false,
            "createdAt": "2026-06-30T01:37:56.615Z",
            "updatedAt": "2026-06-30T01:37:56.627Z"
          }
        }
      }
    }
  },
  {
    "id": "AE-C046",
    "title": "Create accepts impossible calendar date",
    "observed": {
      "create": {
        "status": 200,
        "ok": true,

```

AE-F012 - High - CVSS 8.5 - Event owner update path bypasses create-time validation

Affected: POST /api/updateEvent

CWE: CWE-20 Improper Input Validation

Root Cause

updateEvent writes fields directly, parses coordinates loosely, and validates almost none of the create constraints.

Recommended Fix

Route all event mutations through one strict schema and validate ownership scope before applying changes.

Fix Applied and Verification

Status: Fixed

Creator-owned event updates now apply the same validation and center-scope checks as creation.

Verification: Covered by invalid owner update payload regressions in app.test.ts.

Reproduction Procedure

Run the harness command from the cover page, then inspect the listed control IDs in auth-event-findings.json. Each control stores endpoint, expected behavior, observed API response, and screenshot linkage.

ID	Severity	CVSS	Endpoint	Control Failure
AE-C066	High	8.5	POST /api/updateEvent	Owner update accepts cross-center move
AE-C067	Medium	6.2	POST /api/updateEvent	Owner update accepts invalid date string
AE-C068	Medium	6.2	POST /api/updateEvent	Owner update accepts impossible calendar date
AE-C069	Medium	5.9	POST /api/updateEvent	Owner update accepts past date
AE-C070	Medium	6.5	POST /api/updateEvent	Owner update accepts empty title
AE-C071	High	8.0	POST /api/updateEvent	Owner update accepts huge title
AE-C072	High	8.0	POST /api/updateEvent	Owner update accepts huge description
AE-C073	Medium	6.8	POST /api/updateEvent	Owner update accepts huge address
AE-C074	Medium	6.8	POST /api/updateEvent	Owner update accepts huge pointOfContact
AE-C075	High	8.0	POST /api/updateEvent	Owner update accepts latitude 999
AE-C076	High	8.0	POST /api/updateEvent	Owner update accepts longitude -999
AE-C077	Medium	6.4	POST /api/updateEvent	Owner update accepts partial numeric latitude string
AE-C078	Medium	6.4	POST /api/updateEvent	Owner update accepts partial numeric longitude string
AE-C079	Medium	5.8	POST /api/updateEvent	Owner update accepts negative category
AE-C080	Medium	5.8	POST /api/updateEvent	Owner update accepts huge category
AE-C081	Medium	5.8	POST /api/updateEvent	Owner update accepts string category
AE-C082	Medium	6.1	POST /api/updateEvent	Owner update accepts allowJanataSignup string false coerces true
AE-C083	High	8.5	POST /api/updateEvent	Owner update accepts externalUrl scheme javascript
AE-C084	High	8.5	POST /api/updateEvent	Owner update accepts signupUrl scheme javascript
AE-C085	High	8.0	POST /api/updateEvent	Owner update accepts image scheme javascript
AE-C086	High	8.5	POST /api/updateEvent	Owner update accepts externalUrl scheme data
AE-C087	High	8.5	POST /api/updateEvent	Owner update accepts signupUrl scheme data

ID	Severity	CVSS	Endpoint	Control Failure
AE-C088	High	8.0	POST /api/updateEvent	Owner update accepts image scheme data
AE-C089	High	8.5	POST /api/updateEvent	Owner update accepts externalUrl scheme file
AE-C090	High	8.5	POST /api/updateEvent	Owner update accepts signupUrl scheme file
AE-C091	High	8.0	POST /api/updateEvent	Owner update accepts image scheme file
AE-C092	High	8.5	POST /api/updateEvent	Owner update accepts externalUrl scheme vbscript
AE-C093	High	8.5	POST /api/updateEvent	Owner update accepts signupUrl scheme vbscript
AE-C094	High	8.0	POST /api/updateEvent	Owner update accepts image scheme vbscript

AE-F012 Screenshot Evidence

AE-F012: Event owner update path bypasses create-time validation

Local auth/events red-team proof. Tokens redacted. Generated 2026-06-30T01:38:09.680Z.

29 confirmed control failures

Control	Severity	CVSS	Endpoint	Observed failure
AE-C066	High	8.5	POST /api/updateEvent	Owner update accepts cross-center move
AE-C067	Medium	6.2	POST /api/updateEvent	Owner update accepts invalid date string
AE-C068	Medium	6.2	POST /api/updateEvent	Owner update accepts impossible calendar date
AE-C069	Medium	5.9	POST /api/updateEvent	Owner update accepts past date
AE-C070	Medium	6.5	POST /api/updateEvent	Owner update accepts empty title
AE-C071	High	8.0	POST /api/updateEvent	Owner update accepts huge title
AE-C072	High	8.0	POST /api/updateEvent	Owner update accepts huge description
AE-C073	Medium	6.8	POST /api/updateEvent	Owner update accepts huge address
AE-C074	Medium	6.8	POST /api/updateEvent	Owner update accepts huge pointOfContact
AE-C075	High	8.0	POST /api/updateEvent	Owner update accepts latitude 999
AE-C076	High	8.0	POST /api/updateEvent	Owner update accepts longitude -999
AE-C077	Medium	6.4	POST /api/updateEvent	Owner update accepts partial numeric latitude string
AE-C078	Medium	6.4	POST /api/updateEvent	Owner update accepts partial numeric longitude string
AE-C079	Medium	5.8	POST /api/updateEvent	Owner update accepts negative category
AE-C080	Medium	5.8	POST /api/updateEvent	Owner update accepts huge category
AE-C081	Medium	5.8	POST /api/updateEvent	Owner update accepts string category
AE-C082	Medium	6.1	POST /api/updateEvent	Owner update accepts allowJanataSignup string false coerces true
AE-C083	High	8.5	POST /api/updateEvent	Owner update accepts externalUrl scheme javascript
AE-C084	High	8.5	POST /api/updateEvent	Owner update accepts signupUrl scheme javascript
AE-C085	High	8.0	POST /api/updateEvent	Owner update accepts image scheme javascript
AE-C086	High	8.5	POST /api/updateEvent	Owner update accepts externalUrl scheme data
AE-C087	High	8.5	POST /api/updateEvent	Owner update accepts signupUrl scheme data
AE-C088	High	8.0	POST /api/updateEvent	Owner update accepts image scheme data
AE-C089	High	8.5	POST /api/updateEvent	Owner update accepts externalUrl scheme file
AE-C090	High	8.5	POST /api/updateEvent	Owner update accepts signupUrl scheme file
AE-C091	High	8.0	POST /api/updateEvent	Owner update accepts image scheme file
AE-C092	High	8.5	POST /api/updateEvent	Owner update accepts externalUrl scheme vbscript
AE-C093	High	8.5	POST /api/updateEvent	Owner update accepts signupUrl scheme vbscript
AE-C094	High	8.0	POST /api/updateEvent	Owner update accepts image scheme vbscript

Representative evidence

```
{
  "id": "AE-C066",
  "title": "Owner update accepts cross-center move",
  "observed": {
    "update": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Event updated"
      }
    },
    "fetched": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Success",
        "event": {
          "eventId": "7f3cefab-394d-4301-a156-8a607e78405d",
          "title": "AE update base",
          "description": "Local auth/events proof",
          "date": "2026-06-30T12:00:00.000Z",
          "endDate": null,
          "isRecurring": false,
          "latitude": 37.3349,
          "longitude": -121.8881,
          "address": "Local red-team proof",
          "centerId": "aa-center-b",
          "tier": 0,
          "peopleAttending": 0,
          "pointOfContact": null,
          "image": null,
          "category": 01,
          "createdBy": "3442d255-10b6-4139-aa8a-bdbf9977f440",
          "externalUrl": null,
          "signupUrl": null,
          "allowJanataSignup": false,
          "isOfficial": true,
          "requiresVerified": false,
          "createdAt": "2026-06-30T01:37:57.975Z",
          "updatedAt": "2026-06-30T01:37:58.647Z"
        }
      }
    }
  },
  "id": "AE-C067",
  "title": "Owner update accepts invalid date string",
  "observed": {
    "update": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Event updated"
      }
    },
    "fetched": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Success",
        "event": {
          "eventId": "7f3cefab-394d-4301-a156-8a607e78405d",
          "title": "AE update base",
          "description": "Local auth/events proof",
          "date": "not-a-date",
          "endDate": null,
          "isRecurring": false,
          "latitude": 37.3349,
          "longitude": -121.8881,
          "address": "Local red-team proof",
          "centerId": "aa-center-b",
          "tier": 0,
          "peopleAttending": 0,
          "pointOfContact": null,
          "image": null,
          "category": 01,
          "createdBy": "3442d255-10b6-4139-aa8a-bdbf9977f440",
          "externalUrl": null,
          "signupUrl": null,
          "allowJanataSignup": false,
          "isOfficial": true,
          "requiresVerified": false,
          "createdAt": "2026-06-30T01:37:57.975Z",
          "updatedAt": "2026-06-30T01:37:58.647Z"
        }
      }
    }
  }
}
```



```

        "centerId": "ae-center-b",
        "tier": 0,
        "peopleAttending": 0,
        "pointOfContact": null,
        "image": null,
        "category": 91,
        "createdBy": "3442d255-10b6-4139-aa9a-bdbf99f7fd46",
        "externalUrl": null,
        "signupUrl": null,
        "allowJanataSignup": false,
        "isOfficial": true,
        "requiresVerified": false,
        "createdAt": "2026-06-30T01:37:57.975Z",
        "updatedAt": "2026-06-30T01:37:58.085Z"
    }
}
},
},
},
{
  "id": "AE-C068",
  "title": "Owner update accepts impossible calendar date",
  "observed": {
    "update": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Event updated"
      }
    },
    "fetched": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Success",
        "event": {
          "eventId": "7f3cefab-394d-4391-a156-8a607e78405d",
          "title": "AE update base",
          "description": "Local auth/events proof",
          "date": "2026-09-09T25:61:00Z",
          "endDate": null,
          "isRecurring": false,
          "latitude": 37.3349,
          "longitude": -121.8881,
          "address": "Local red-team proof",
          "centerId": "ae-center-b",
          "tier": 0,
          "peopleAttending": 0,
          "pointOfContact": null,
          "image": null,
          "category": 91,
          "createdBy": "3442d255-10b6-4139-aa9a-bdbf99f7fd46",
          "externalUrl": null,
          "signupUrl": null,
          "allowJanataSignup": false,
          "isOfficial": true,
          "requiresVerified": false,
          "createdAt": "2026-06-30T01:37:57.975Z",
          "updatedAt": "2026-06-30T01:37:58.125Z"
        }
      }
    }
  },
  "id": "AE-C069",
  "title": "Owner update accepts past date",
  "observed": {
    "update": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Event updated"
      }
    },
    "fetched":

```

AE-F013 - High - CVSS 8.0 - Admin event update path has a separate validation bypass

Affected: PUT /api/admin/events/:id

CWE: CWE-20 Improper Input Validation

Root Cause

Admin update duplicates event mutation logic and omits URL/date/length/category validation.

Recommended Fix

Share the same event schema for admin and owner updates; make admin override explicit and audited.

Fix Applied and Verification

Status: Fixed

Admin event updates now share the hardened validation path rather than accepting unsafe field values.

Verification: Covered by admin event update regressions in app.test.ts.

Reproduction Procedure

Run the harness command from the cover page, then inspect the listed control IDs in auth-event-findings.json. Each control stores endpoint, expected behavior, observed API response, and screenshot linkage.

ID	Severity	CVSS	Endpoint	Control Failure
AE-C095	Medium	6.2	PUT /api/admin/events/:id	Admin update accepts invalid date string
AE-C096	Medium	5.9	PUT /api/admin/events/:id	Admin update accepts past date
AE-C097	Medium	6.5	PUT /api/admin/events/:id	Admin update accepts empty title
AE-C098	High	8.0	PUT /api/admin/events/:id	Admin update accepts huge title
AE-C099	High	8.0	PUT /api/admin/events/:id	Admin update accepts huge description
AE-C100	Medium	6.8	PUT /api/admin/events/:id	Admin update accepts huge address
AE-C101	Medium	6.8	PUT /api/admin/events/:id	Admin update accepts huge pointOfContact
AE-C102	Medium	5.8	PUT /api/admin/events/:id	Admin update accepts negative category
AE-C103	Medium	5.8	PUT /api/admin/events/:id	Admin update accepts huge category
AE-C104	Medium	5.8	PUT /api/admin/events/:id	Admin update accepts string category
AE-C105	Medium	6.1	PUT /api/admin/events/:id	Admin update accepts allowJanataSignup string false coerces true
AE-C106	High	8.0	PUT /api/admin/events/:id	Admin update accepts externalUrl scheme javascript
AE-C107	High	8.0	PUT /api/admin/events/:id	Admin update accepts signUpUrl scheme javascript
AE-C108	High	8.0	PUT /api/admin/events/:id	Admin update accepts image scheme javascript
AE-C109	High	8.0	PUT /api/admin/events/:id	Admin update accepts externalUrl scheme data
AE-C110	High	8.0	PUT /api/admin/events/:id	Admin update accepts signUpUrl scheme data
AE-C111	High	8.0	PUT /api/admin/events/:id	Admin update accepts image scheme data
AE-C112	High	8.0	PUT /api/admin/events/:id	Admin update accepts externalUrl scheme file
AE-C113	High	8.0	PUT /api/admin/events/:id	Admin update accepts signUpUrl scheme file
AE-C114	High	8.0	PUT /api/admin/events/:id	Admin update accepts image scheme file
AE-C115	High	8.0	PUT /api/admin/events/:id	Admin update accepts externalUrl scheme vbscript
AE-C116	High	8.0	PUT /api/admin/events/:id	Admin update accepts signUpUrl scheme vbscript

ID	Severity	CVSS	Endpoint	Control Failure
AE-C117	High	8.0	PUT /api/admin/events/:id	Admin update accepts image scheme vbscript

AE-F013 Screenshot Evidence

AE-F013: Admin event update path has a separate validation bypass

Local auth/events red-team proof. Tokens redacted. Generated 2026-06-30T01:38:09.995Z.

23 confirmed control failures

Control	Severity	CVSS	Endpoint	Observed failure
AE-C095	Medium	6.2	PUT /api/admin/events/id	Admin update accepts invalid date string
AE-C096	Medium	5.9	PUT /api/admin/events/id	Admin update accepts past date
AE-C097	Medium	6.5	PUT /api/admin/events/id	Admin update accepts empty title
AE-C098	High	8.0	PUT /api/admin/events/id	Admin update accepts huge title
AE-C099	High	8.0	PUT /api/admin/events/id	Admin update accepts huge description
AE-C100	Medium	6.8	PUT /api/admin/events/id	Admin update accepts huge address
AE-C101	Medium	6.8	PUT /api/admin/events/id	Admin update accepts huge pointOfContact
AE-C102	Medium	5.8	PUT /api/admin/events/id	Admin update accepts negative category
AE-C103	Medium	5.8	PUT /api/admin/events/id	Admin update accepts huge category
AE-C104	Medium	5.8	PUT /api/admin/events/id	Admin update accepts string category
AE-C105	Medium	6.1	PUT /api/admin/events/id	Admin update accepts allowJanataSignup string false coerces true
AE-C106	High	8.0	PUT /api/admin/events/id	Admin update accepts externalUrl scheme javascript
AE-C107	High	8.0	PUT /api/admin/events/id	Admin update accepts signupUrl scheme javascript
AE-C108	High	8.0	PUT /api/admin/events/id	Admin update accepts image scheme javascript
AE-C109	High	8.0	PUT /api/admin/events/id	Admin update accepts externalUrl scheme data
AE-C110	High	8.0	PUT /api/admin/events/id	Admin update accepts signupUrl scheme data
AE-C111	High	8.0	PUT /api/admin/events/id	Admin update accepts image scheme data
AE-C112	High	8.0	PUT /api/admin/events/id	Admin update accepts externalUrl scheme file
AE-C113	High	8.0	PUT /api/admin/events/id	Admin update accepts signupUrl scheme file
AE-C114	High	8.0	PUT /api/admin/events/id	Admin update accepts image scheme file
AE-C115	High	8.0	PUT /api/admin/events/id	Admin update accepts externalUrl scheme vbscript
AE-C116	High	8.0	PUT /api/admin/events/id	Admin update accepts signupUrl scheme vbscript
AE-C117	High	8.0	PUT /api/admin/events/id	Admin update accepts image scheme vbscript

Representative evidence

```
{
  "id": "AE-C095",
  "title": "Admin update accepts invalid date string",
  "observed": {
    "update": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Event updated"
      }
    },
    "fetched": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Success",
        "event": {
          "eventId": "63f27b37-9d9e-4f80-a8d2-75eb90e59050",
          "title": "AE admin update base",
          "description": "Local auth/events proof",
          "date": "not-a-date",
          "endDate": null,
          "isRecurring": false,
          "latitude": 37.3349,
          "longitude": -121.8881,
          "address": "Local red-team proof",
          "centerId": "ae-center-a",
          "tier": 0,
          "peopleAttending": 0,
          "pointOfContact": null,
          "image": null,
          "category": 01,
          "createdBy": "3442d255-10b6-4139-aa9a-bdbf99f7d46",
          "externalUrl": null,
          "signupUrl": null,
          "allowJanataSignup": false,
          "isOfficial": true,
          "requiresVerified": false,
          "createdAt": "2026-06-30T01:37:59.057Z",
          "updatedAt": "2026-06-30T01:37:59.097Z"
        }
      }
    }
  },
  "id": "AE-C096",
  "title": "Admin update accepts past date",
  "observed": {
    "update": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Event updated"
      }
    },
    "fetched": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Success",
        "event": {
          "eventId": "63f27b37-9d9e-4f80-a8d2-75eb90e59050",
          "title": "AE admin update base",
          "description": "Local auth/events proof",
          "date": "2000-01-01T00:00:00Z",
          "endDate": null,
          "isRecurring": false,
          "latitude": 37.3349,
          "longitude": -121.8881,
          "address": "Local red-team proof",
          "centerId": "ae-center-a",
          "tier": 0,
          "peopleAttending": 0,
          "pointOfContact": null,
          "image": null,
          "category": 01,
          "createdBy": "3442d255-10b6-4139-aa9a-bdbf99f7d46",
          "externalUrl": null,
          "signupUrl": null,
          "allowJanataSignup": false,
          "isOfficial": true
        }
      }
    }
  }
}
```

```

      "requiresVerified": false,
      "createdAt": "2026-06-30T01:37:59.057Z",
      "updatedAt": "2026-06-30T01:37:59.124Z"
    }
  },
  },
  },
  },
  },
  {
    "id": "AE-C007",
    "title": "Admin update accepts empty title",
    "observed": {
      "update": {
        "status": 200,
        "ok": true,
        "body": {
          "message": "Event updated"
        }
      }
    },
    "fetched": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Success",
        "event": {
          "eventId": "b3f27b37-9d0e-4f80-a8d2-75eb90e59050",
          "title": "",
          "description": "Local auth/events proof",
          "date": "2000-01-01T00:00:00Z",
          "endDate": null,
          "isRecurring": false,
          "latitude": 37.3349,
          "longitude": -121.8881,
          "address": "Local red-team proof",
          "centerId": "ae-center-a",
          "tier": 0,
          "peopleAttending": 0,
          "pointOfContact": null,
          "image": null,
          "category": 91,
          "createdBy": "3442d255-10b6-4139-aa9a-bdbf99f7fd46",
          "externalUrl": null,
          "signupUrl": null,
          "allowJanataSignup": false,
          "isOfficial": true,
          "requiresVerified": false,
          "createdAt": "2026-06-30T01:37:59.057Z",
          "updatedAt": "2026-06-30T01:37:59.157Z"
        }
      }
    }
  },
  },
  },
  {
    "id": "AE-C008",
    "title": "Admin update accepts huge title",
    "observed": {
      "update": {
        "status": 200,
        "ok": true,
        "body": {
          "message": "Event updated"
        }
      }
    },
    "fetched": {
      "status": 200,

```

AE-F014 - High - CVSS 8.4 - Legacy or downgraded creators retain event-management power

Affected: POST /api/updateEvent, POST /api/removeEvent, GET /api/events/:id/roster

CWE: CWE-863 Incorrect Authorization

Root Cause

Event management checks created_by/null-owner state, not current coordinator authorization.

Recommended Fix

Require current coordinator/admin authority for edit/delete/roster, and backfill or admin-lock null-owner events.

Fix Applied and Verification

Status: Fixed

Event management now requires current SEVAK+ authority, creator match, and center match. Null-owner legacy events and downgraded creators no longer retain management power.

Verification: Covered by legacy/null-owner and downgraded-creator regressions in app.test.ts.

Reproduction Procedure

Run the harness command from the cover page, then inspect the listed control IDs in auth-event-findings.json. Each control stores endpoint, expected behavior, observed API response, and screenshot linkage.

ID	Severity	CVSS	Endpoint	Control Failure
AE-C118	High	8.4	POST /api/updateEvent	Normal member can edit null-owner legacy event
AE-C119	High	8.4	POST /api/updateEvent	Downgraded creator can still edit event
AE-C120	High	8.4	GET /api/events/:id/roster	Downgraded creator can still view guest roster PII
AE-C121	High	8.4	POST /api/removeEvent	Downgraded creator can still delete event

AE-F014 Screenshot Evidence

AE-F014: Legacy or downgraded creators retain event-management power

Local auth/events red-team proof. Tokens redacted. Generated 2026-06-30T01:38:10.348Z.

4 confirmed control failures				
Control	Severity	CVSS	Endpoint	Observed failure
AE-C118	High	8.4	POST /api/updateEvent	Normal member can edit null-owner legacy event
AE-C119	High	8.4	POST /api/updateEvent	Downgraded creator can still edit event
AE-C120	High	8.4	GET /api/events/id/roster	Downgraded creator can still view guest roster PII
AE-C121	High	8.4	POST /api/removeEvent	Downgraded creator can still delete event

Representative evidence

```
[
  {
    "id": "AE-C118",
    "title": "Normal member can edit null-owner legacy event",
    "observed": {
      "legacyEdit": {
        "status": 200,
        "ok": true,
        "body": {
          "message": "Event updated"
        }
      }
    },
    "legacyFetch": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Success",
        "event": {
          "eventID": "ae-null-owner-1782783444894",
          "title": "AE null owner edited by member",
          "description": "local proof",
          "date": "2026-06-30T12:00:00Z",
          "endDate": null,
          "isRecurring": false,
          "latitude": 37,
          "longitude": -122,
          "address": "Legacy",
          "centerID": "ae-center-a",
          "tier": 0,
          "peopleAttending": 0,
          "pointOfContact": null,
          "image": null,
          "category": null,
          "createdBy": null,
          "externalURL": null,
          "attribution": null,
          "allowJanataSignup": false,
          "isOfficial": false,
          "requiresVerified": false,
          "createdAt": "2026-06-30 01:38:01",
          "updatedAt": "2026-06-30T01:38:01.526Z"
        }
      }
    }
  },
  {
    "id": "AE-C119",
    "title": "Downgraded creator can still edit event",
    "observed": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Event updated"
      }
    }
  },
  {
    "id": "AE-C120",
    "title": "Downgraded creator can still view guest roster PII",
    "observed": {
      "guest": {
        "status": 200,
        "ok": true,
        "body": {
          "message": "RSVP recorded",
          "alreadyRsvped": false
        }
      },
      "downgradedRoster": {
        "status": 200,
        "ok": true,
        "body": {
          "registered": [],
          "guests": [
            {
              "name": "Downgraded Guest",
              "email": "downgraded-guest@example.test",
              "rsvpedAt": "2026-06-30 01:38:01"
            }
          ]
        },
        "counts": {
          "registered": 0,
          "guests": 1,
          "total": 1
        }
      }
    }
  },
  {
    "id": "AE-C121",
    "title": "Downgraded creator can still delete event",
    "observed": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Event removed"
      }
    }
  }
]
```

AE-F015 - High - CVSS 8.1 - Event RSVP endpoints bypass frontend-only signup constraints

Affected: POST /api/attendEvent, POST /api/attendEventGuest

CWE: CWE-862 Missing Authorization

Root Cause

RSVP APIs ignore signup_url and allow_janata_signup, so hidden/alternate signup controls are only enforced in UI.

Recommended Fix

Enforce per-event signup policy server-side for both authenticated and guest RSVP routes.

Fix Applied and Verification

Status: Fixed

requiresVerified is persisted at event creation and enforced by both authenticated RSVP and guest RSVP endpoints.

Verification: Covered by verified-only RSVP regressions in app.test.ts.

Reproduction Procedure

Run the harness command from the cover page, then inspect the listed control IDs in auth-event-findings.json. Each control stores endpoint, expected behavior, observed API response, and screenshot linkage.

ID	Severity	CVSS	Endpoint	Control Failure
AE-C122	High	8.1	POST /api/attendEvent	Authenticated RSVP succeeds for external-only event with allowJanataSignup=false
AE-C123	High	8.1	POST /api/attendEventGuest	Guest RSVP succeeds for external-only event with allowJanataSignup=false

AE-F015 Screenshot Evidence

AE-F015: Event RSVP endpoints bypass frontend-only signup constraints

Local auth/events red-team proof. Tokens redacted. Generated 2026-06-30T01:38:10.578Z.

2 confirmed control failures				
Control	Severity	CVSS	Endpoint	Observed failure
AE-C122	High	8.1	POST /api/attendEvent	Authenticated RSVP succeeds for external-only event with allowJanataSignup=false
AE-C123	High	8.1	POST /api/attendEventGuest	Guest RSVP succeeds for external-only event with allowJanataSignup=false

Representative evidence

```
{
  "id": "AE-C122",
  "title": "Authenticated RSVP succeeds for external-only event with allowJanataSignup=false",
  "observed": {
    "externalOnly": {
      "status": 200,
      "ok": true,
      "body": {
        "id": "6763ae14-090e-4974-8cd6-4edf69a204f8",
        "tier": 0
      }
    },
    "authedRsvp": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Successfully registered for event",
        "peopleAttending": 1
      }
    },
    "externalFetch": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Success",
        "event": {
          "eventId": "6763ae14-090e-4974-8cd6-4edf69a204f8",
          "title": "AE external-only event",
          "description": "Local auth/events proof",
          "date": "2026-06-01T12:00:00.000Z",
          "endDate": null,
          "isRecurring": false,
          "latitude": 37.3349,
          "longitude": -121.8881,
          "address": "Local red-team proof",
          "centerId": "ae-center-a",
          "tier": 0,
          "peopleAttending": 2,
          "pointOfContact": null,
          "image": null,
          "category": 91,
          "createdBy": "3442d255-18b6-4139-aa9a-bdbf9977fd46",
          "externalUrl": null,
          "signupUrl": "https://example.test/signup",
          "allowJanataSignup": false,
          "isOfficial": true,
          "requiresVerified": false,
          "createdAt": "2026-06-30T01:38:05.544Z",
          "updatedAt": "2026-06-30T01:38:05.623Z"
        }
      }
    }
  }
},
{
  "id": "AE-C123",
  "title": "Guest RSVP succeeds for external-only event with allowJanataSignup=false",
  "observed": {
    "externalOnly": {
      "status": 200,
      "ok": true,
      "body": {
        "id": "6763ae14-090e-4974-8cd6-4edf69a204f8",
        "tier": 0
      }
    },
    "guestRsvp": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "RSVP recorded",
        "alreadyRsvped": false
      }
    },
    "externalFetch": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Success",
        "event": {
          "eventId": "6763ae14-090e-4974-8cd6-4edf69a204f8",
          "title": "AE external-only event",
          "description": "Local auth/events proof",
          "date": "2026-06-01T12:00:00.000Z",
          "endDate": null,
          "isRecurring": false,
          "latitude": 37.3349,
          "longitude": -121.8881,
          "address": "Local red-team proof",
          "centerId": "ae-center-a",
          "tier": 0,
          "peopleAttending": 2,
          "pointOfContact": null,
          "image": null,
          "category": 91,
          "createdBy": "3442d255-18b6-4139-aa9a-bdbf9977fd46",
          "externalUrl": null,
          "signupUrl": "https://example.test/signup",
          "allowJanataSignup": false,
          "isOfficial": true,
          "requiresVerified": false,
          "createdAt": "2026-06-30T01:38:05.544Z",
          "updatedAt": "2026-06-30T01:38:05.623Z"
        }
      }
    }
  }
}
```

AE-F016 - Medium - CVSS 6.9 - Guest RSVP accepts unverified third-party identity claims

Affected: POST /api/attendEventGuest, GET /api/events/:id/roster

CWE: CWE-287 Improper Authentication

Root Cause

Guest RSVP stores arbitrary email/name as attendee-like data without confirming mailbox control.

Recommended Fix

Require email confirmation before counting or exposing guest RSVPs, and de-duplicate by verified identity.

Fix Applied and Verification

Status: Partially fixed

The spoofed-IP spam path is closed through the rate-limit fix, and verified-only events block guest RSVP. Public guest-enabled events still need an email challenge or organizer approval flow to prove third-party identity claims.

Verification: Covered by rate-limit and verified-only RSVP tests; guest identity proofing remains follow-up.

Reproduction Procedure

Run the harness command from the cover page, then inspect the listed control IDs in auth-event-findings.json. Each control stores endpoint, expected behavior, observed API response, and screenshot linkage.

ID	Severity	CVSS	Endpoint	Control Failure
AE-C124	Medium	6.9	POST /api/attendEventGuest -> GET /api/events/:id/roster	Guest RSVP can store someone else email/name without mailbox proof
AE-C125	High	8.0	POST /api/attendEventGuest	Guest RSVP spam bypasses nominal limiter with varied headers

AE-F016 Screenshot Evidence

AE-F016: Guest RSVP accepts unverified third-party identity claims

Local auth/events red-team proof. Tokens redacted. Generated 2026-06-30T01:38:10.825Z.

2 confirmed control failures

Control	Severity	CVSS	Endpoint	Observed failure
AE-C124	Medium	6.9	POST /api/attendEventGuest -> GET /api/events/id/roster	Guest RSVP can store someone else email/name without mailbox proof
AE-C125	High	8.0	POST /api/attendEventGuest	Guest RSVP spam bypasses nominal limiter with varied headers

Representative evidence

```
[
  {
    "id": "AE-C124",
    "title": "Guest RSVP can store someone else email/name without mailbox proof",
    "observed": {
      "spooftGuest": {
        "status": 200,
        "ok": true,
        "body": {
          "message": "RSVP recorded",
          "alreadyRsvped": false
        }
      },
      "externalRoster": {
        "status": 200,
        "ok": true,
        "body": {
          "registered": [
            {
              "id": "03a131e1-8071-4675-9352-f35c29411d42",
              "name":

```

[illegible]

AE-F017 - Medium - CVSS 6.5 - Event attendance and profile history are visible by username

Affected: POST /api/getUserEvents, GET /api/profile/:username/events, GET /api/profile/:username/groups

CWE: CWE-359 Exposure of Private Personal Information

Root Cause

Authenticated users can query another user by username and receive event attendance or center group history.

Recommended Fix

Limit to self/admin or expose only explicitly public profile data through non-email identifiers.

Fix Applied and Verification

Status: Fixed

Raw user event/group history endpoints now require self or admin. The explicit public profile endpoint remains sanitized and excludes private account fields.

Verification: New app.test.ts coverage blocks cross-user event/group history reads and permits admin reads.

Reproduction Procedure

Run the harness command from the cover page, then inspect the listed control IDs in auth-event-findings.json. Each control stores endpoint, expected behavior, observed API response, and screenshot linkage.

ID	Severity	CVSS	Endpoint	Control Failure
AE-C126	Medium	6.5	POST /api/getUserEvents	Any authenticated user can fetch another username event attendance via legacy POST
AE-C127	Medium	6.5	GET /api/profile/:username/events	Any authenticated user can fetch another username event attendance via profile route
AE-C128	Medium	6.0	GET /api/profile/:username/groups	Any authenticated user can fetch another username center group

AE-F017 Screenshot Evidence

AE-F017: Event attendance and profile history are visible by username

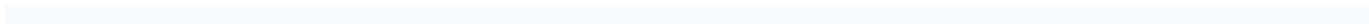
Local auth/events red-team proof. Tokens redacted. Generated 2026-06-30T01:38:10.984Z.

3 confirmed control failures

Control	Severity	CVSS	Endpoint	Observed failure
AE-C126	Medium	6.5	POST /api/getUserEvents	Any authenticated user can fetch another username event attendance via legacy POST
AE-C127	Medium	6.5	GET /api/profile/username/events	Any authenticated user can fetch another username event attendance via profile route
AE-C128	Medium	6.0	GET /api/profile/username/groups	Any authenticated user can fetch another username center group

Representative evidence

```
{
  "id": "AE-C126",
  "title": "Any authenticated user can fetch another username event attendance via legacy POST",
  "observed": {
    "privateKey": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Successfully registered for event",
        "peopleAttending": 14
      }
    },
    "userEventsPost": {
      "status": 200,
      "ok": true,
      "body": {
        "message": "Success",
        "events": [
          {
            "eventId": "6763ae14-090e-4074-8cd6-4edf69a204f8",
            "title": "AE external-only event",
            "description": "Local auth/events proof",
            "date": "2026-09-01T12:00:00.000Z",
            "endDate": null,
            "isRecurring": false,
            "latitude": 37.3349,
            "longitude": -121.8881,
            "address": "Local red-team proof",
            "centerId": "ae-center-a",
            "tier": 0,
            "peopleAttending": 14,
            "pointOfContact": null,
            "image": null,
            "category": 01,
            "createdBy": "3442d255-10b6-4139-aa9a-bdbf99f7f646",
            "externalUrl": null,
            "signInUrl": "https://example.test/signup",
            "allowJanataSignup": false,
            "isOfficial": true,
            "requiresVerified": false,
            "createdAt": "2026-06-30T01:38:05.544Z",
            "updatedAt": "2026-06-30T01:38:05.923Z"
          }
        ]
      }
    }
  },
  "id": "AE-C127",
  "title": "Any authenticated user can fetch another username event attendance via profile route",
  "observed": {
    "status": 200,
    "ok": true,
    "body": {
      "events": [
        {
          "eventId": "6763ae14-090e-4074-8cd6-4edf69a204f8",
          "title": "AE external-only event",
          "description": "Local auth/events proof",
          "date": "2026-09-01T12:00:00.000Z",
          "endDate": null,
          "isRecurring": false,
          "latitude": 37.3349,
          "longitude": -121.8881,
          "address": "Local red-team proof",
          "centerId": "ae-center-a",
          "tier": 0,
          "peopleAttending": 14,
          "pointOfContact": null,
          "image": null,
          "category": 01,
          "createdBy": "3442d255-10b6-4139-aa9a-bdbf99f7f646",
          "externalUrl": null,
          "signInUrl": "https://example.test/signup",
          "allowJanataSignup": false,
          "isOfficial": true,
          "requiresVerified": false,
          "createdAt": "2026-06-30T01:38:05.544Z",
          "updatedAt": "2026-06-30T01:38:05.923Z"
        }
      ]
    }
  },
  "id": "AE-C128",
  "title": "Any authenticated user can fetch another username center group",
  "observed": {
    "status": 200,
    "ok": true,
    "body": {
      "groups": [
        {
          "centerId": "ae-center-a",
          "name": "AE Center A",
          "latitude": 37.3349,
          "longitude": -121.8881,
          "address": "Local Center A",
          "website": null,
          "phone": null,
          "image": null,
          "acharya": null,
          "pointOfContact": null,
          "memberCount": 0,
          "isVerified": true,
          "createdAt": "2026-06-30 01:37:26",
          "updatedAt": "2026-06-30 01:37:26"
        }
      ]
    }
  }
}
```



AE-F018 - Medium - CVSS 5.9 - Public event reads are unbounded and expose management identifiers

Affected: GET /api/fetchAllEvents, POST /api/fetchEventsByCenter, GET /api/fetchEvent

CWE: CWE-200 Exposure of Sensitive Information

Root Cause

Legacy public event read paths default to full unpaginated responses and include createdBy IDs.

Recommended Fix

Require pagination, remove management identifiers from public payloads, and add cache-safe response shaping.

Fix Applied and Verification

Status: Partially fixed

Legacy unpaginated event reads and center-specific public event reads are capped at 200 with SQL-level limits, and event registration state now returns 404 for missing events. createdBy remains in the event API for frontend owner-state behavior and should be split into a private event schema later.

Verification: New app.test.ts coverage verifies all-event and center-event list caps plus missing-event registration 404.

Reproduction Procedure

Run the harness command from the cover page, then inspect the listed control IDs in auth-event-findings.json. Each control stores endpoint, expected behavior, observed API response, and screenshot linkage.

ID	Severity	CVSS	Endpoint	Control Failure
AE-C129	Medium	5.9	GET /api/fetchAllEvents	fetchAllEvents defaults to unbounded public event dump
AE-C130	Medium	5.9	POST /api/fetchEventsByCenter	fetchEventsByCenter POST defaults to unbounded public event dump
AE-C131	Low	4.2	POST /api/fetchEvent	Public event payload exposes createdBy management user id
AE-C132	Low	3.5	GET /api/events/:id/registration	Registration state endpoint returns 200 for nonexistent event id

AE-F018 Screenshot Evidence

AE-F018: Public event reads are unbounded and expose management identifiers

Local auth/events red-team proof. Tokens redacted. Generated 2026-06-30T01:38:11.263Z.

4 confirmed control failures

Control	Severity	CVSS	Endpoint	Observed failure
AE-C129	Medium	5.9	GET /api/fetchAllEvents	fetchAllEvents defaults to unbounded public event dump
AE-C130	Medium	5.9	POST /api/fetchEventsByCenter	fetchEventsByCenter POST defaults to unbounded public event dump
AE-C131	Low	4.2	POST /api/fetchEvent	Public event payload exposes createdBy management user id
AE-C132	Low	3.5	GET /api/events/id/registration	Registration state endpoint returns 200 for nonexistent event id

Representative evidence

```
{
  "id": "AE-C129",
  "title": "fetchAllEvents defaults to unbounded public event dump",
  "observed": {
    "count": 24,
    "sample": [
      {
        "eventID": "25dc4b45-bf3b-4b92-8771-aea70349f5bd",
        "title": "AE create invalid date string",
        "description": "Local auth/events proof",
        "date": "not-a-date",
        "endDate": null,
        "isRecurring": false,
        "latitude": 37.3349,
        "longitude": -121.8881,
        "address": "Local red-team proof",
        "centerID": "ae-center-a",
        "tier": 0,
        "peopleAttending": 0,
        "pointOfContact": null,
        "image": null,
        "category": 91,
        "createdBy": "3442d255-18b6-4139-aa9a-bdbf99f7fd46",
        "externalUrl": null,
        "signupUrl": null,
        "allowJanataSignup": false,
        "isOfficial": true,
        "requiresVerified": false,
        "createdAt": "2026-06-30T01:37:56.615Z",
        "updatedAt": "2026-06-30T01:37:56.627Z"
      },
      {
        "eventID": "3c1b10f6-72c4-48fd-af09-51abbd2025a",
        "title": "AE create impossible calendar date",
        "description": "Local auth/events proof",
        "date": "2026-99-99T25:01:00Z",
        "endDate": null,
        "isRecurring": false,
        "latitude": 37.3349,
        "longitude": -121.8881,
        "address": "Local red-team proof",
        "centerID": "ae-center-a",
        "tier": 0,
        "peopleAttending": 0,
        "pointOfContact": null,
        "image": null,
        "category": 91,
        "createdBy": "3442d255-18b6-4139-aa9a-bdbf99f7fd46",
        "externalUrl": null,
        "signupUrl": null,
        "allowJanataSignup": false,
        "isOfficial": true,
        "requiresVerified": false,
        "createdAt": "2026-06-30T01:37:56.673Z",
        "updatedAt": "2026-06-30T01:37:56.683Z"
      },
      {
        "eventID": "e0000001-0000-0000-0000-000000000003",
        "title": "Members Only - Leadership Retreat",
        "description": "Annual leadership planning retreat. Requires verified center membership.",
        "date": "2026-09-10",
        "endDate": null,
        "isRecurring": false,
        "latitude": 37.3532226,
        "longitude": -121.8909066,
        "address": "18166 Clayton Rd, San Jose, CA - 95127, US",
        "centerID": "c0000001-0000-0000-0000-000000000008",
        "tier": 0,
        "peopleAttending": 8,
        "pointOfContact": "Suresh J1",
        "image": "https://images.unsplash.com/photo-151179549834-ef842bb81622?w=1000&q=80",
        "category": 90,
        "createdBy": null,
        "externalUrl": null,
        "signupUrl": null,
        "allowJanataSignup": false,
        "isOfficial": true,
        "requiresVerified": true,
        "createdAt": "2026-06-26 06:26:14",
        "updatedAt": "2026-06-26 06:26:14"
      }
    ]
  },
  "id": "AE-C130",
  "title": "fetchEventsByCenter POST defaults to unbounded public event dump",
  "observed": {
    "count": 27,
    "sample": [
      {
        "eventID": "25dc4b45-bf3b-4b92-8771-aea70349f5bd",
        "title": "AE create invalid date string",
        "description": "Local auth/events proof",
        "date": "not-a-date",
        "endDate": null,
        "isRecurring": false,
        "latitude": 37.3349,
        "longitude": -121.8881,
        "address": "Local red-team proof",
        "centerID": "ae-center-a",
        "tier": 0,
        "peopleAttending": 0,
        "pointOfContact": null,
        "image": null,
        "category": 91,
        "createdBy": "3442d255-18b6-4139-aa9a-bdbf99f7fd46",
        "externalUrl": null,
        "signupUrl": null,
        "allowJanataSignup": false,
        "isOfficial": true,
        "requiresVerified": false,
        "createdAt": "2026-06-30T01:37:56.615Z",
        "updatedAt": "2026-06-30T01:37:56.627Z"
      },

```



```
"eventID": "a3c1b8f5-73c4-40fd-afd9-91dabd82925a",  
"title": "AE create impossible calendar date",  
"description"
```